



5G Workshop Defcon

AKIB SAYYED
akibsayyed@matrixshell.com

TABLE OF CONTENT

- 5G ARCHITECTURE & CORE
- SETTING UP LAB

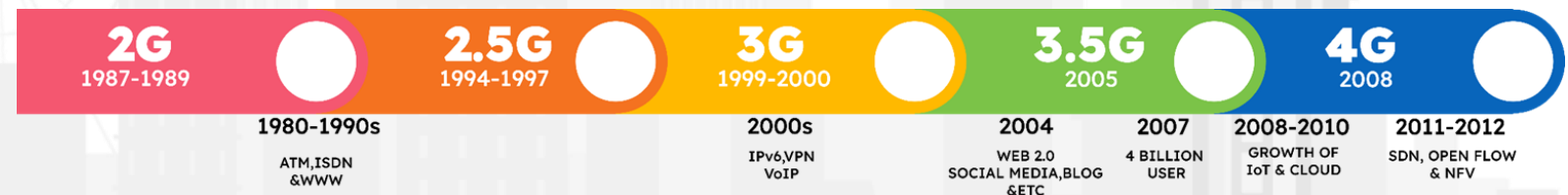
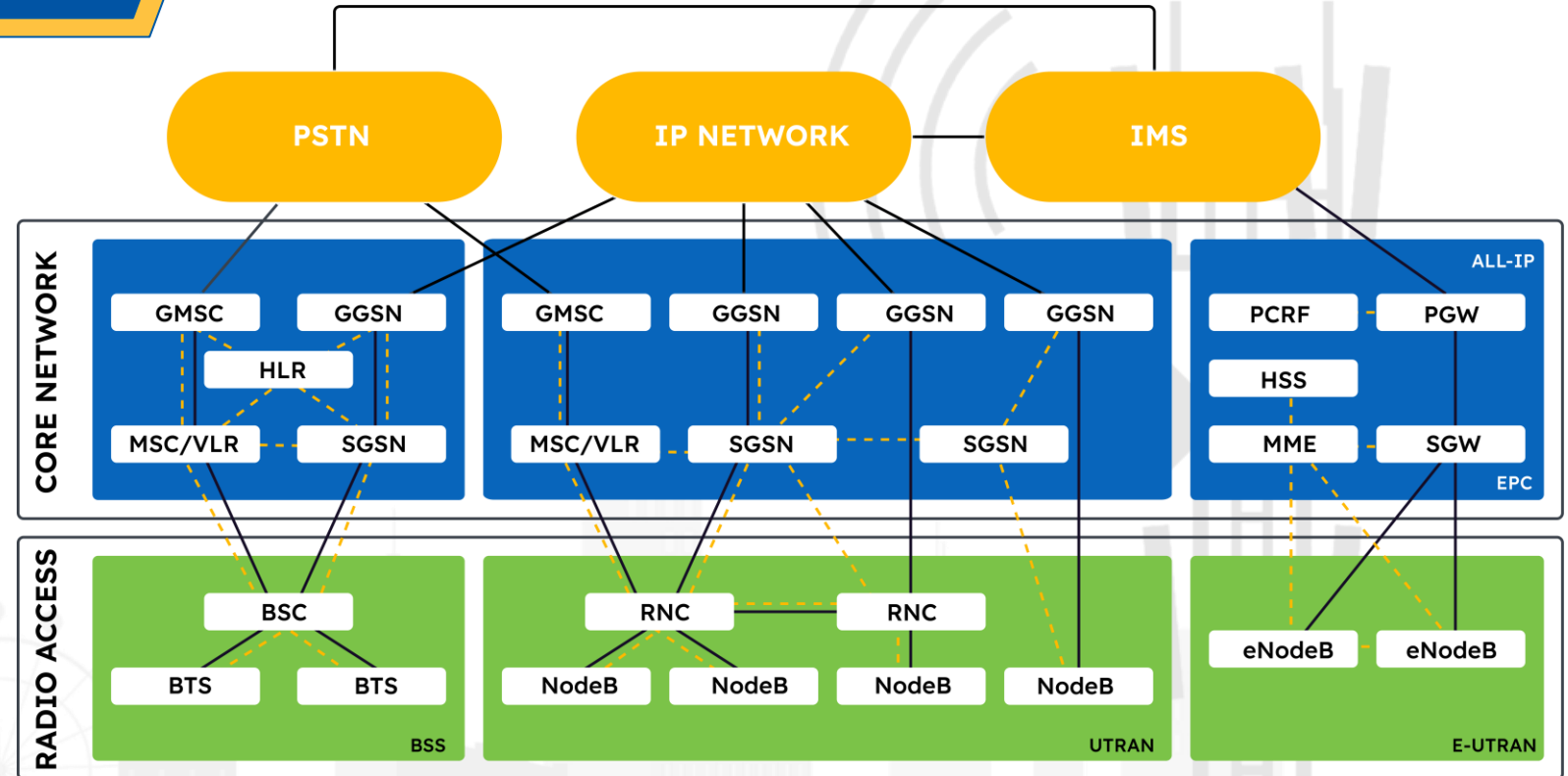


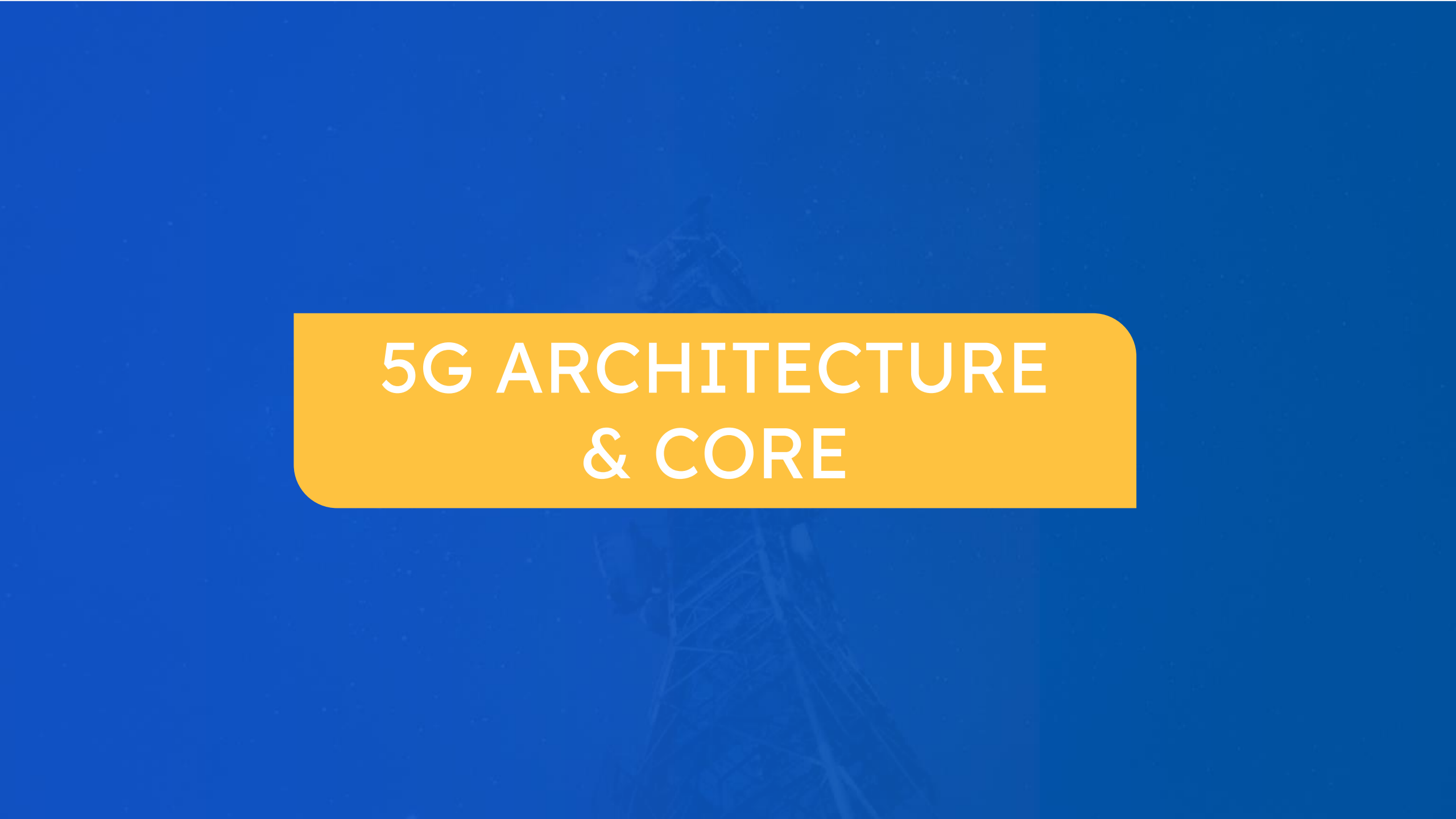
TABLE OF CONTENT

The background features a stylized, light gray illustration of a city skyline. On the left, a tall 5G antenna tower is depicted with several curved lines representing signal waves emanating from it. The skyline includes various building silhouettes and a Ferris wheel on the right side. A solid blue horizontal bar is at the top, and a blue diagonal shape is in the bottom right corner.

- UNDERSTANDING THREATS IN 5G
- TESTING REQUIREMENTS IN 5G

WHAT WE HAD TILL NOW



The background of the slide is a solid blue color. In the center, there is a faint, semi-transparent image of a 5G network tower. The tower is a lattice structure with multiple levels of antennas or equipment. It is positioned slightly to the left of the center. The overall aesthetic is modern and technological.

5G ARCHITECTURE & CORE

END-TO-END ARCHITECTURE FOR 5G

5G SYSTEM



UE



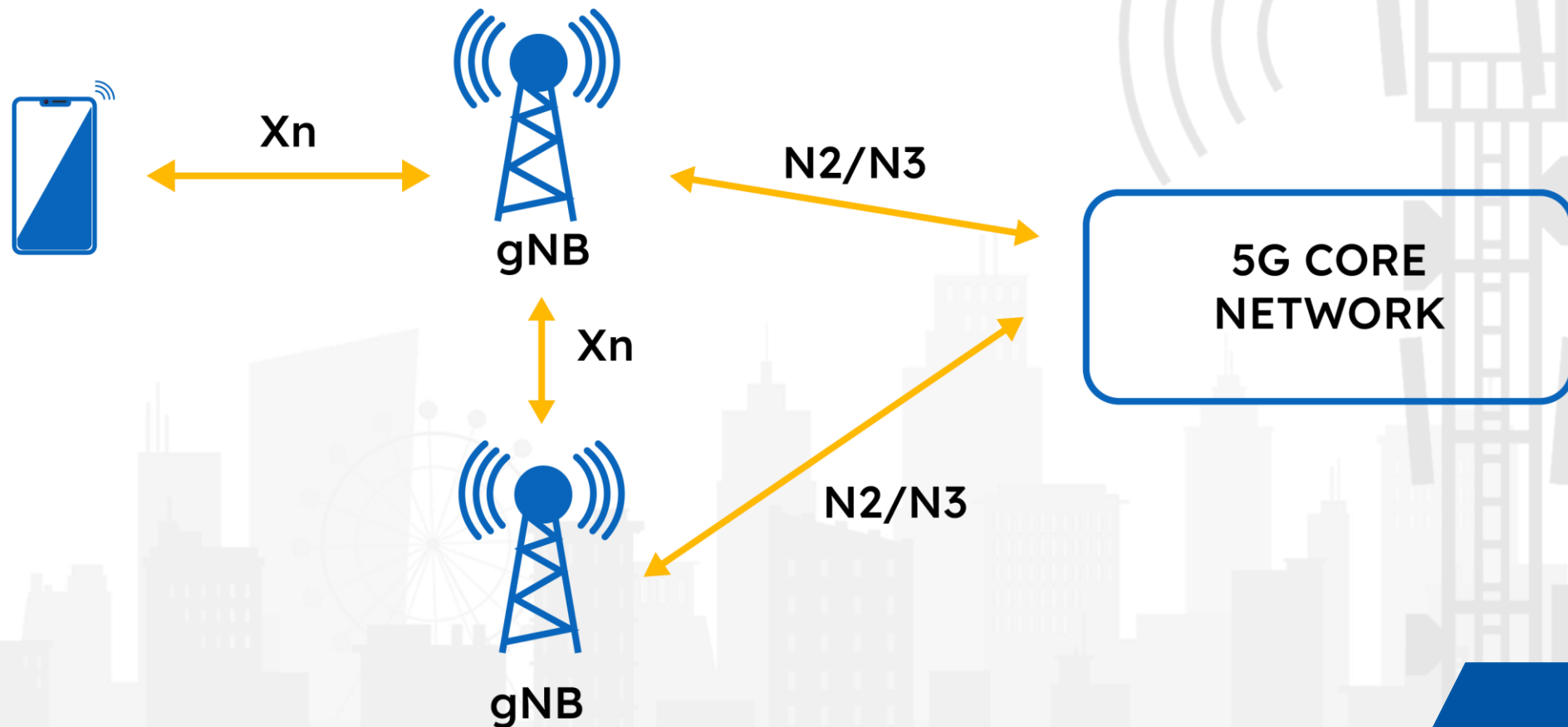
NR Uu

NG-RAN

5G CORE

DATA
NETWORK

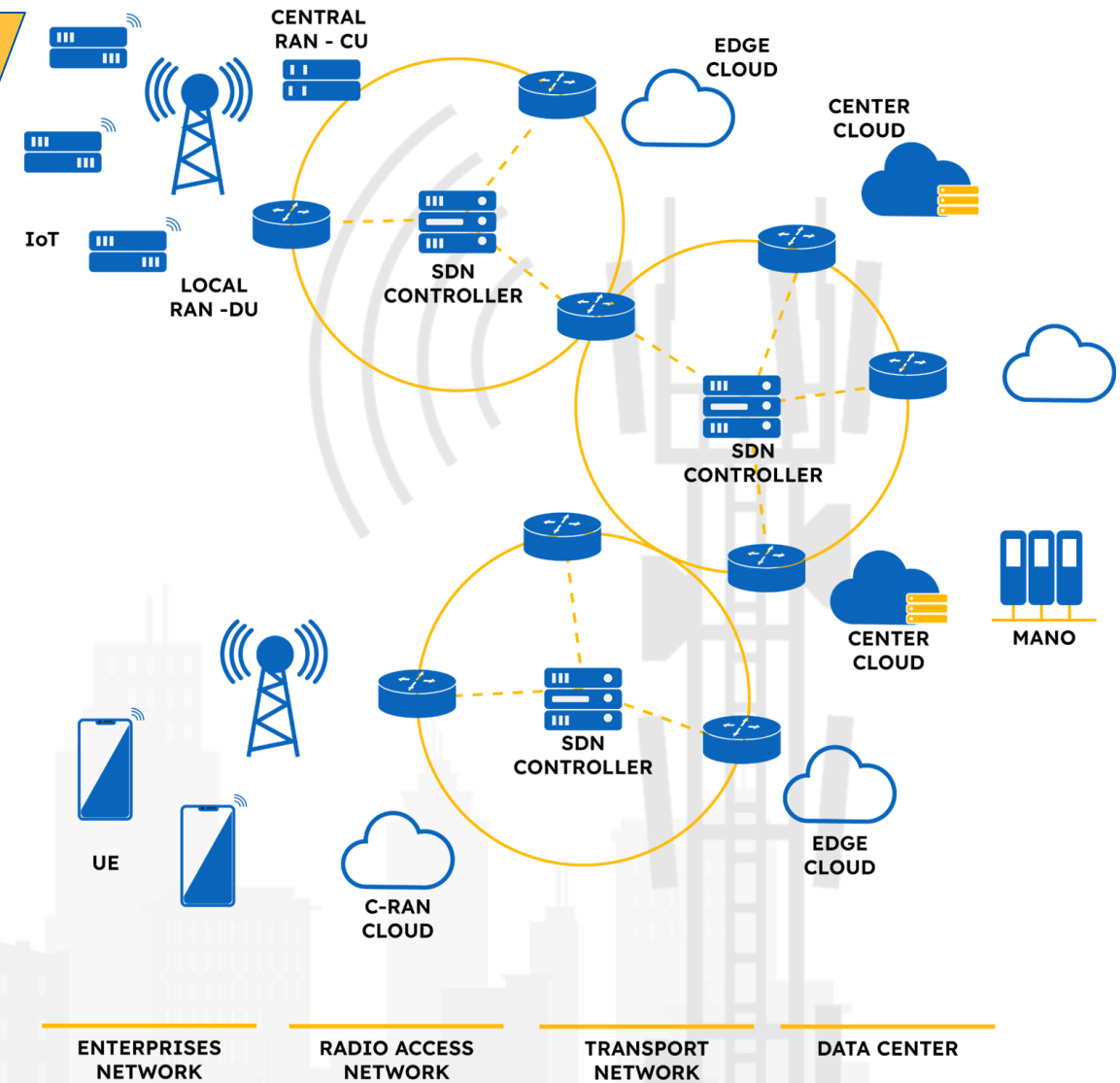
NG-RAN ARCHITECTURE



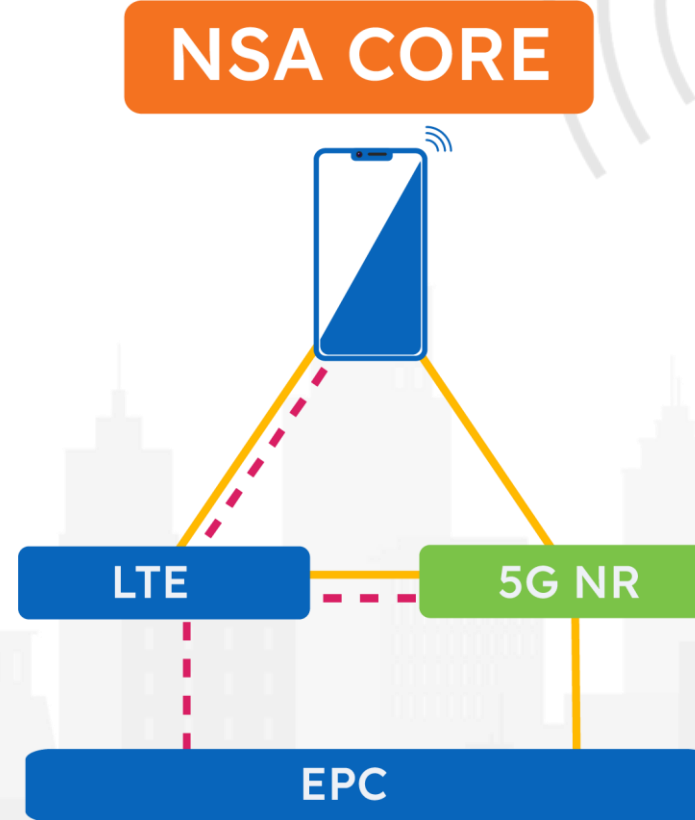
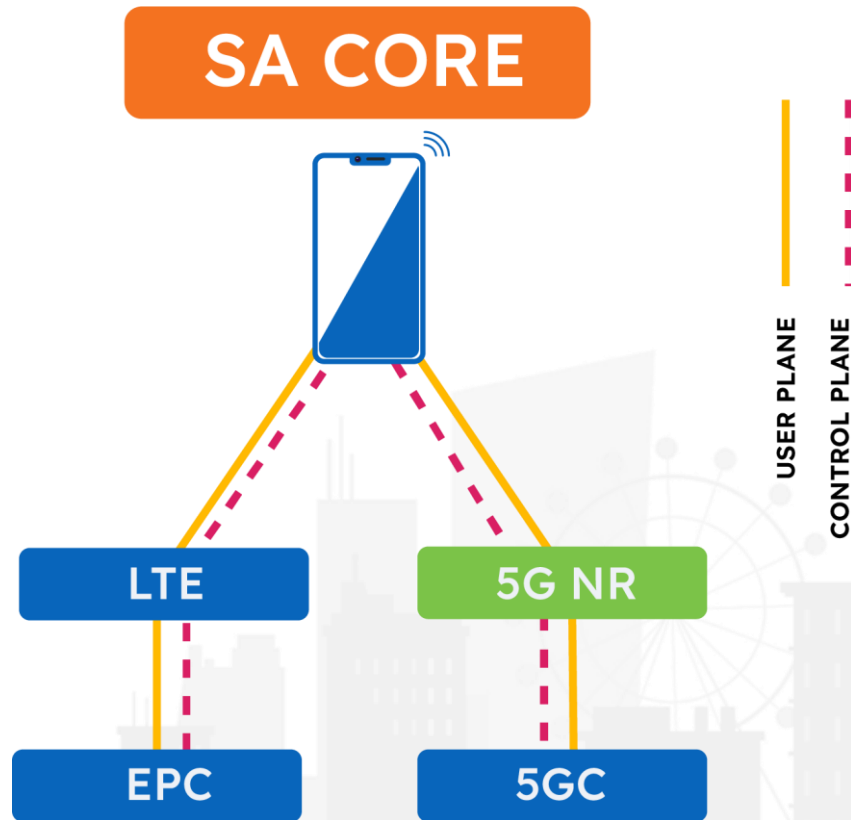
GENERIC TELECOM NETWORK ARCHITECTURE

The physical architecture shows all hardware components required for a Telecom Network :

- Enterprise Network: UE, NB-IOT, Connected Car, Cloud Services.
- Radio Access Network consisting of VRAN MEC and Routers;
- Transport network (backhaul) consisting of Edge Cloud, and SDN controller/switches and Data centre consisting of Central Cloud, MANO and SDN controllers.

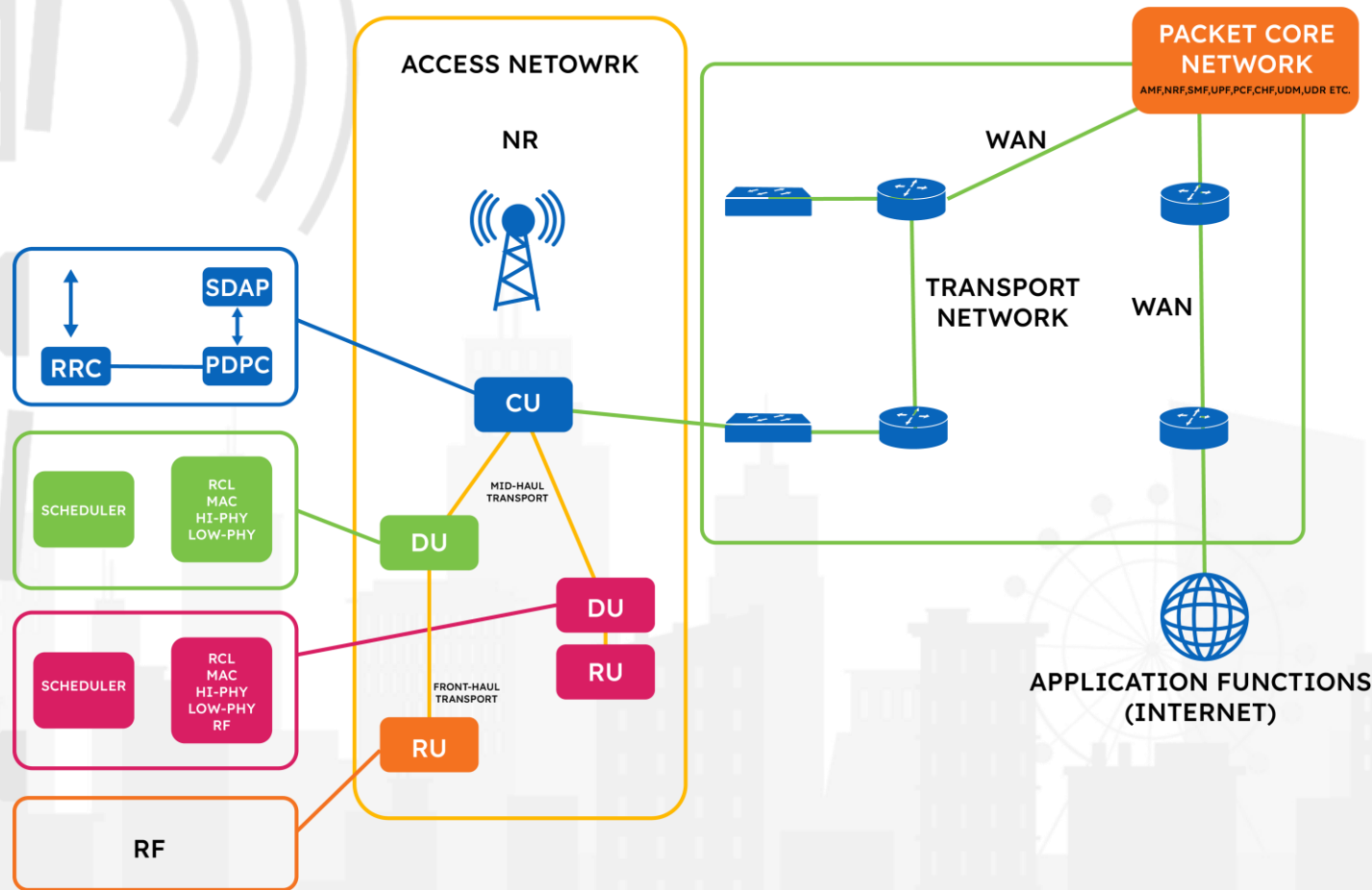


5G NETWORK DEPLOYMENT



A GENERIC 5G SA

GENERIC Telco EXPLAINED



ACCESS NETWORK

- It's a radio components, basically the g-nodeb (gnb), also known as new radio (NR).
- Access network components can be of following types:
 - AIO RAN: all in one gnodeb.
 - Split RAN: RU+DU+CU.
- Ru(remote/radio unit or RRH) :
 - Actual transmitting device ,receive/transmit IQ samples for TX or RX.
- Du (distributed unit):
 - Processes radio link control (rlc), medium access. control (mac), and physical (phy) functions on tx/rx data.
 - Du is controlled by cu.
- Cu (central unit):
 - Processes service delivery adaptation protocol (SDAP) for NR, packet data convergence protocol (PDCP), radio resource control (RRC),
 - SDAP : responsible for mapping between a quality-

of-service flow from the 5G core network and a data radio bearer.

PDCP : which uses packet processing components, including ciphering and header compression.

RRC : responsible for controlling radio channels.

- Uses CPRI /eCPRI for connection between RU and DU
- Next is the mid-haul, which connects the DU and the CU.
- Transport network using eCPRI/CPRI needs PTP switches to function efficiently

PACKET CORE NETWORK

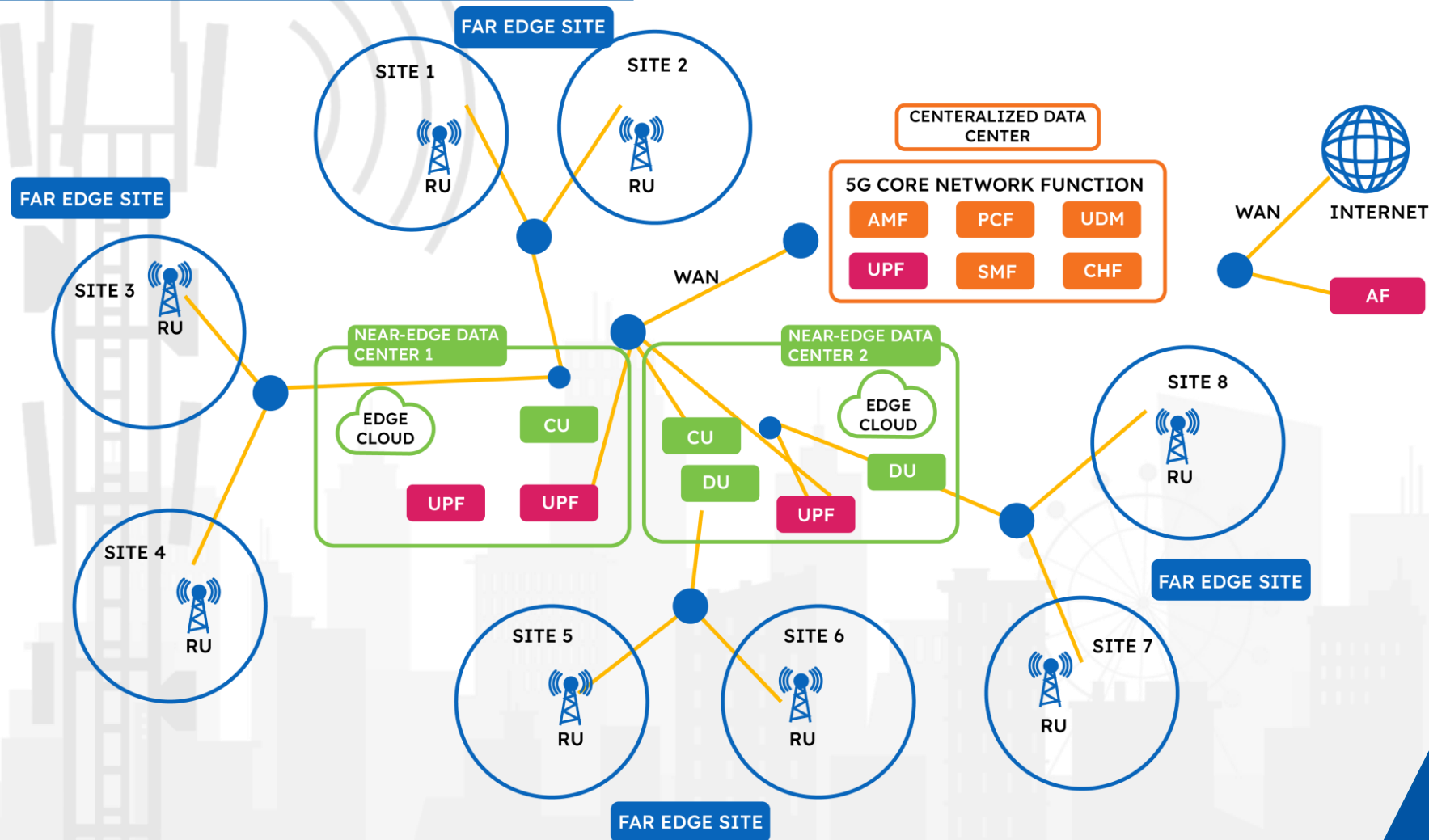
- Packet Core consist of multiple Network Function in different forms such as VM/Container
- They follow a producer-consumer model.
- Each of these NFs provides a set of services to different NFs
- And they consume services from other NFs.
- These NFs provide
 - mobility management
 - session management
 - control, user plane processing
 - Charging and subscription management
 - traffic policing, and QoS control

TRANSPORT NETWORK

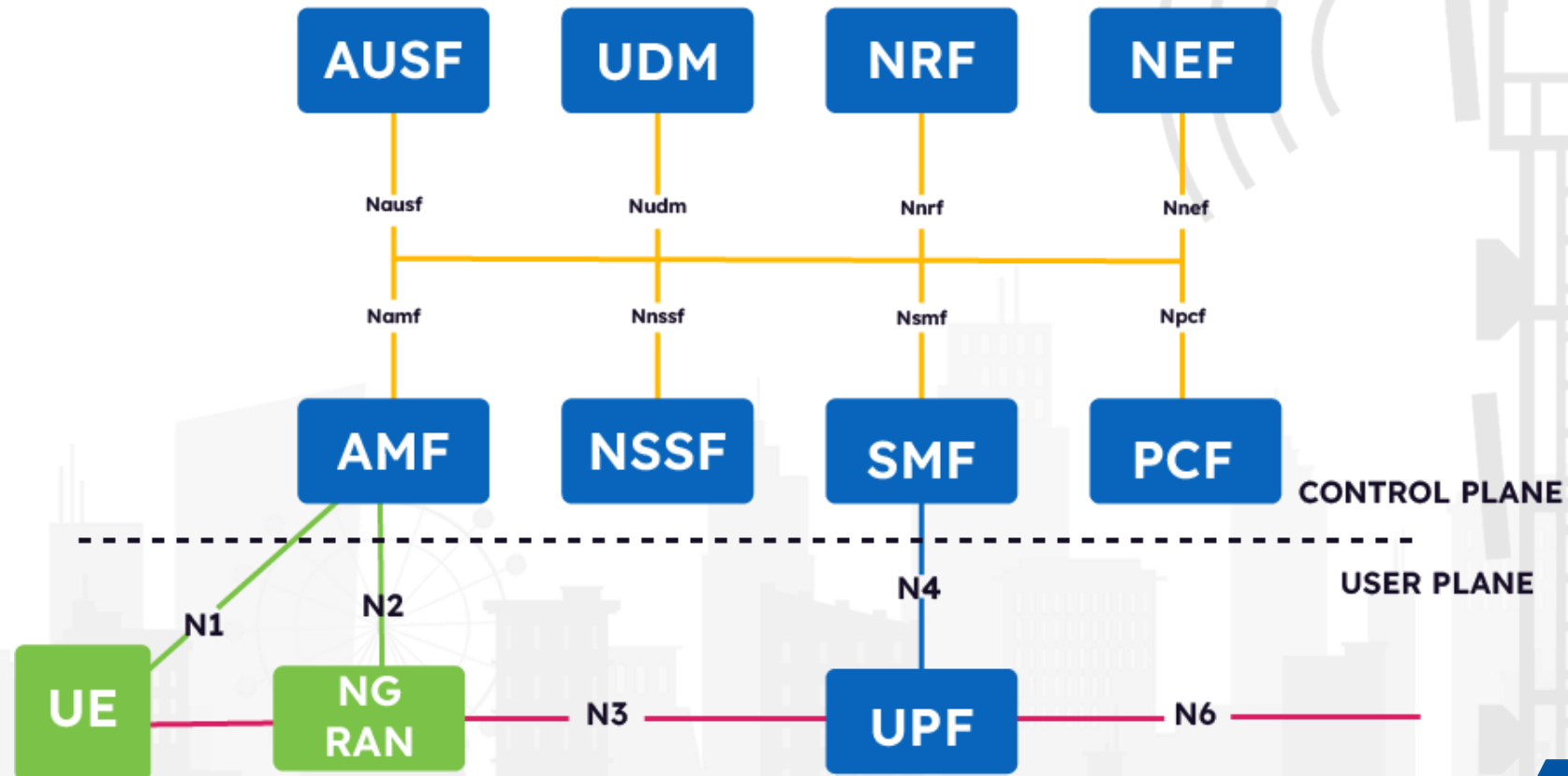
- The 5G Transport Network reply of optical fiber based transport network
- Uses MPLS network mostly for low latency
- Usually network uses DWDM, Optical Bus based network



Network In Glance



BIRD EYE VIEW



THE AMF

- Handle NGAP/NAS Interface towards gNB
 - Protocols used are N1 (NAS) /N2 (NGAP)
- Used HTTP/2 Protocol towards SBI (Service Based Interface)
- Procedures are
 - Registration /Mobility Management
 - UE Authentication
 - Network slice-specific authentication and authorization
 - Provide UE mobility and reachability
 - inter-RAT handovers to LTE or the WLAN (N3-IWF) .

THE SMF

- Responsible for
 - Session establishment, modification, and release
 - Responsible for maintaining the tunnel between the UPF and the access node (the gNB).
 - UE IP address allocation and management pre-configured IP pool or from UPF or external Data Network
 - Collecting data charging info and providing it to the billing Network Function (CHF) for billing purposes.
 - Inform AMF for Downlink Data for UE
 - PCSCF discovery for voice sessions.
- Protocols :
 - HTTP/2
 - PFCP

THE UPF

- The UPF is the main data plane NF
- Uses N3 Interface with gNB for data traffic in GTP-U protocol
- Uses PFCP protocol with SMF for control plane message by the N4 interface
- only Node in 5GC for data path.
- It's a anchor point for intra- and inter-RAT mobility.
- Responsible for
 - Packet Data forwarding
 - May Support Inspection
 - forward data packets to law enforcement servers.
 - triggers downlink data notifications to the SMF when data arrives for

THE PCF

- Governs network behavior by providing policy framework
- Policies are provided to SMF and then passed down to UPF
- Policy decisions are accessed from UDR
- Communicates with CHF for collecting usage info so rules can be sent to SMF
- Interacts with AF for application level policies

THE NEF

- Securely exposes the NF capabilities and events to third-party AFs.
- The NEF stores information to and retrieves information from the UDF located in the same PLMN and securely provides information from non-3GPP networks.
- It also translates information between the AF and the 5GS.
- It masks network and user information for external AFs based on the network policy.

THE NRF

- Used for service discovery.
- Provides address(IP/PORT/URLS) of NF when requested by Other NF
- Also used to discover P-CSCF for IMS calls.
- Maintains a profile of all the NFs that are registered with it and maintains a record of the services they offer.
- It maintains the health of the NFs it discovers and keeps track of the load information.
- In the case of network slicing, multiple NRFs can be deployed at the PLMN level, the shared slice level, or a slice-specific level.
- The NRF maintains the following information on registered NFs:
 - NF instance IDs
 - NF types
 - PLMN IDs
 - Network slice identifiers
 - IP addresses or FQDNs of the NFs
 - and many more

THE UDM

- Main repository for subscriber information and engages in subscriber management.
- Stores and manages the Subscription Permanent Identifier (SUPI) for each subscriber
- Performs de-concealment of the SUPI to reveal privacy-protected subscriber information (the Subscription Concealed Identifier (SUCI)).
- Provides access authentication based on the user subscription – for example, for roaming users, it verifies whether the subscriber has roaming privileges in the requested network.
- Stores and Provides current AMF/SMF of specific UE
- Maintains the SMF/Data Network Name (DNN) assignment for the UE

THE UDR

- Serves as the data store for the subscription information for UE.
- Helps in the storage and retrieval of subscription data by the UDM.
- Helps with storage and the retrieval of policy data for the PCF.
- Stores and retrieves structured data for exposure via the NEF:
- UDR is an intra-PLMN NF and it will store and retrieve information only for the NFs within the same PLMN.

THE AUSF



- The AUSF supports authentication for 3GPP access and non-3GPP access;
- it is responsible for storing keys and implementing an EAP authentication server

THE SMSF

- The SMSF is responsible for providing the functionality of supporting SMS over NAS.
- Performs SMS management subscription data checking and conducts SMS delivery accordingly.
- It relays the message from the device toward the SMS-GMSC, IWMSC, or SMS router, and vice versa
- Generates CDRs related to the SMS.
- Notifies the SMS-GMSC to inform the UDM when the UE is unavailable to receive SMS.

THE SEPP

- The Security Edge Protection Proxy (SEPP) is used to enable different 5G networks to securely interconnect with each other.
- It is responsible for providing end-to-end confidentiality and integrity between two operator networks in roaming cases. Hence, this NF is used to aid roaming partners to interconnect securely.
- It carried out message filtering and policing on inter-PLMN control plane interfaces: It hides the network topology of the two networks it connects from each other.
- The SEPP protects the connection between service producers and service consumers.
- It acts as a service relay between the actual service provider (in one network) and the service consumer (in a different network), but for both the service producer and the consumer, the result of the service relay is transparent. Hence, it is equivalent to a direct service interaction.

PDU sessions

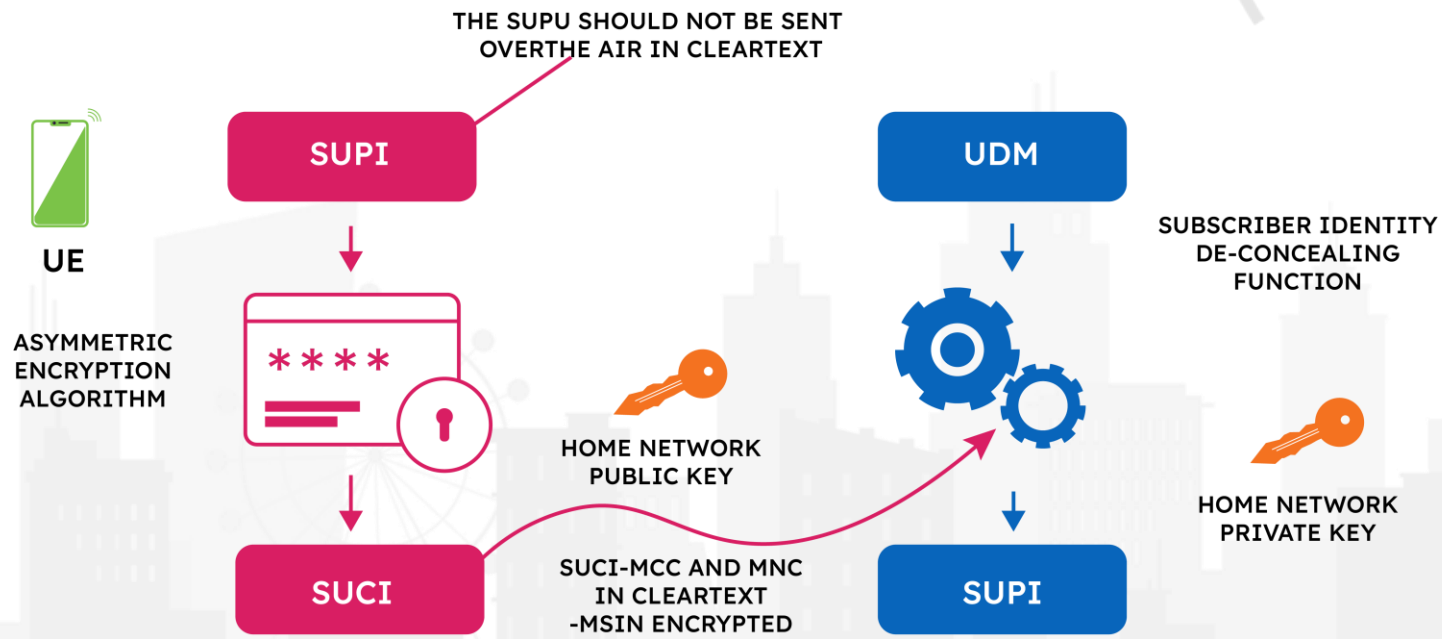
- A PDU session is the logical connection between the UE and the data network.
- It is by the means of this logical connection that the UE is able to browse data, place calls, and so on.
- This connection determines the QoS experienced by the user.
- Certain PDU sessions require a guaranteed QoS, which must be provided by the network if the PDU session is accepted. Hence, the network must reserve resources for this kind of PDU session.
- A classic example of this is an emergency call.
- When a user places an emergency call, the network must admit the call and provide the necessary resources.

Some Terms

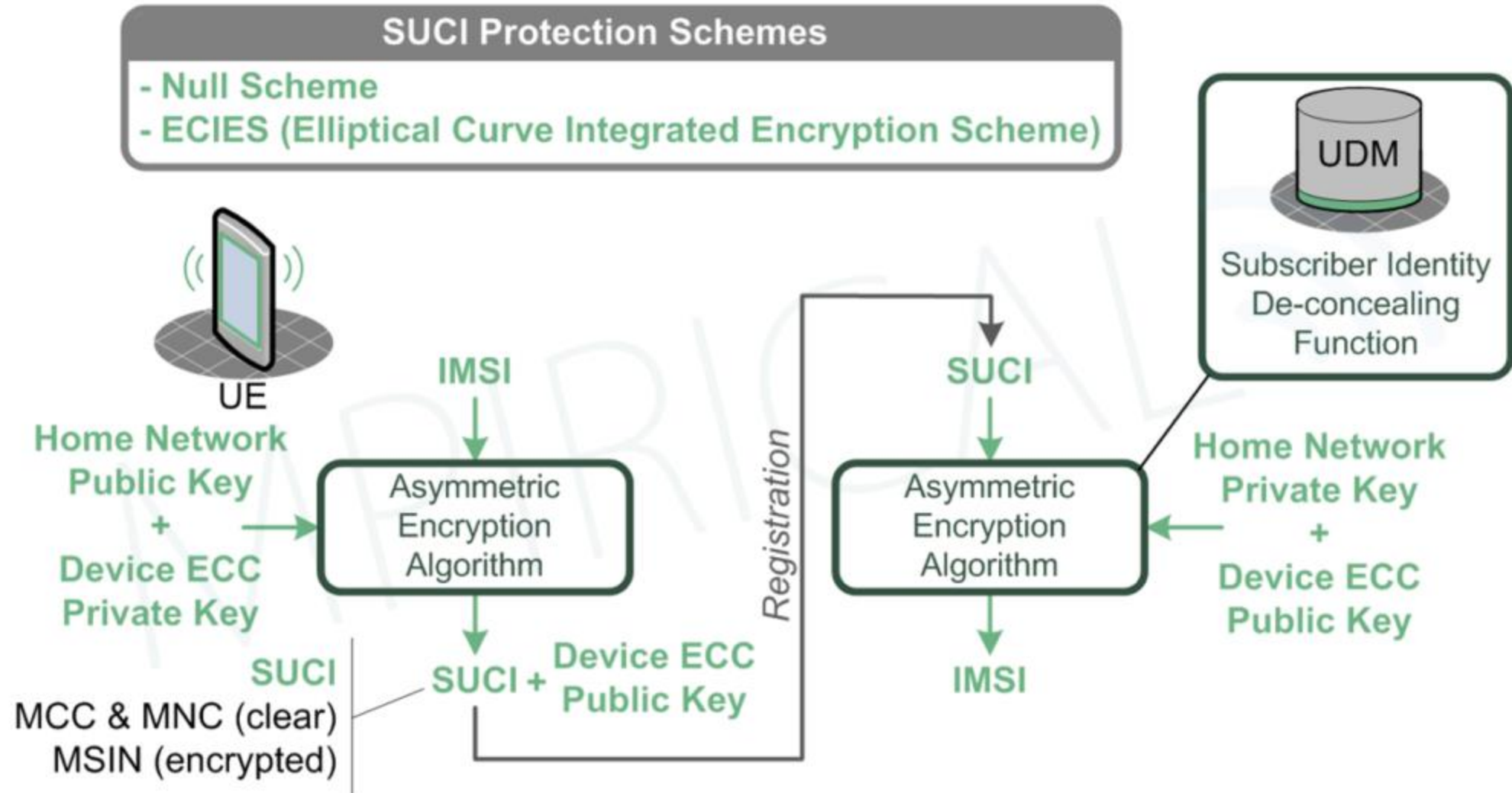
- Tracking Area :
 - 5G network coverage is broken into Tracking Areas.
 - And Each tracking area contains multiple cells
- Cell ID
 - In 5G, a service provider identifies a cell using an NCI (NR Cell Identity).
 - This is a 36bit identity which can be concatenated with the PLMN-Id (PLMN Identifier) to form the NCGI (NR Cell Global Identity).

5G IDENTIFIERS

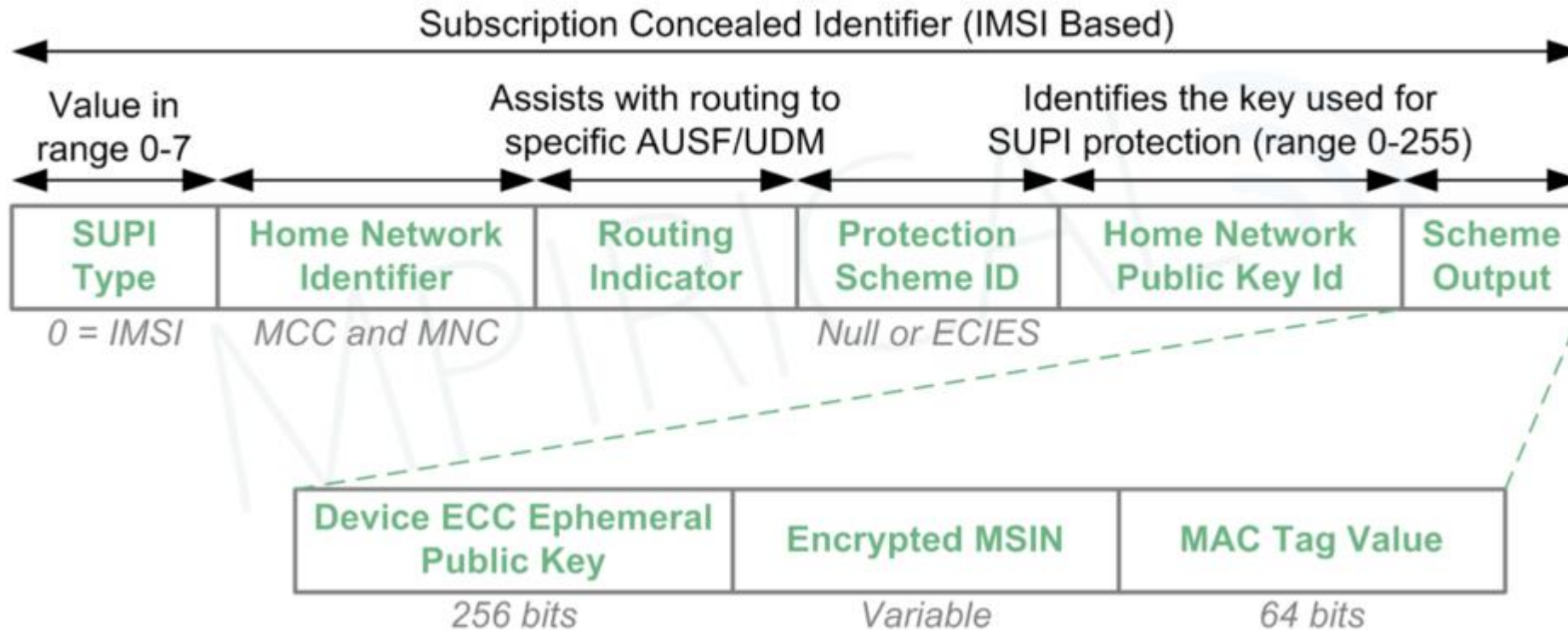
- In telecommunication systems, the network operator allocates a SIM card to every device. This SIM card is associated not just with the mobile number but also with a SUPI in the 5GS. It was known as International Mobile Subscriber Identity (IMSI) in the 4G world.



SUCI and SUPI



SUCI and SUPI



GLOBALLY UNIQUE TEMPORARY IDENTIFIERS (GUTIs)

- These identifiers are frequently changed and used for identifying a UE over the air. However, in some situations, like the first user registration, the SUPI is used, and then from thereon, a GUTI is used:

GUAMI- GLOBALLY UNIQUE AMF ID

GUAMI- GLOBALLY UNIQUE AMF ID

MCC

MNC

AMF
REGION
ID

AMF
SET
ID

AMF
POINTER

5G
TMSI

GUAMI- UNIQUELY IDENTIFIES THE AMF

5G TMSI - UNIQUELY IDENTIFIES THE UE WITHIN THE AMF

AMF REGION ID- IDENTIFIES THE REGION

AMF SET ID- IDENTIFIES A SPECIFIC AMF SET WITHIN THE REGION

AMF POINTER - UNIQUELY IDENTIFIES THE AMF WITHIN THE AMF SET

THE DNN

2G/3G/4G

**ACCESS POINT
NAME (APN)**

APN NETWORK IDENTIFIES
APN OPERATOR IDENTIFIES



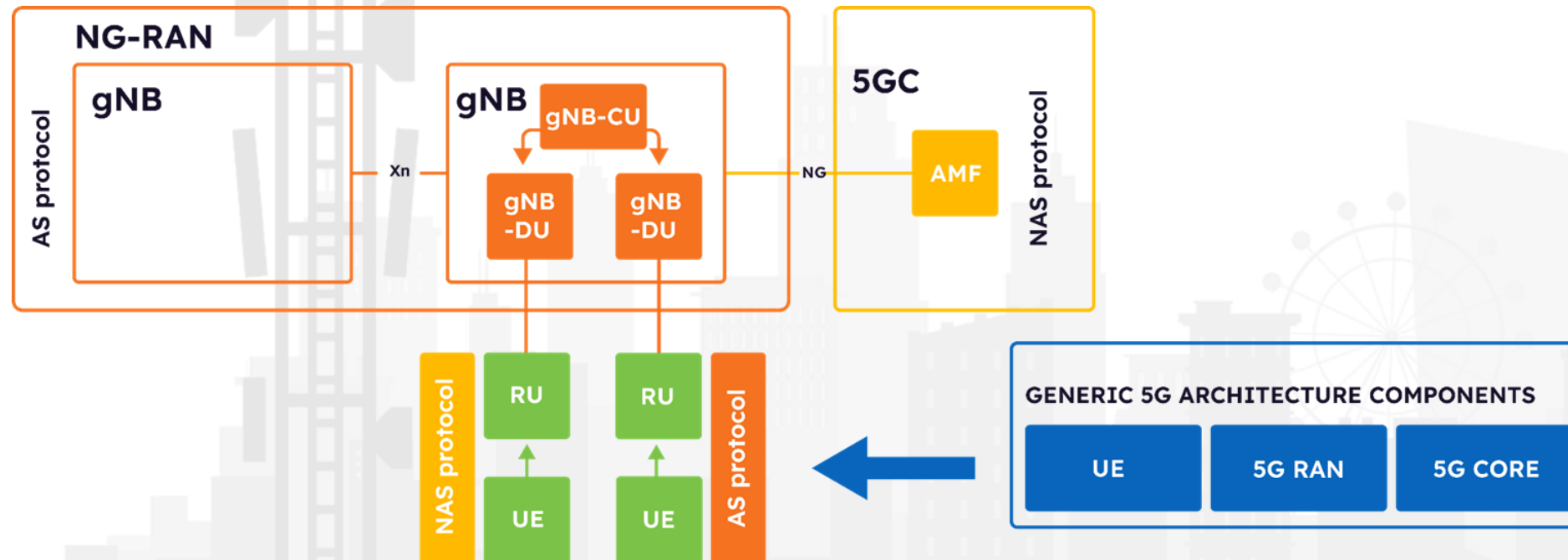
IDENTIFIES THE DATA NETWORK
IDENTIFIES THE PLMN

5G

**DATA NETWORK
NAME (DNN)**

5G RAN ARCHITECTURE

The latest 3GPP specifications on NG-RAN, identifies as the main innovation the split of the F1 interface into Centralized Unit (CU) and Distributed Unit (DU), with a Service Data Adaptation Protocol (SDAP). The SDAP architecture includes a Packet Data Conversion Protocol (PDCP) located in the CU and an Air Radio Link Control (ARLC) located in the DU.



Cont..

- **User Equipment (UE)** User equipment is any device used by users to communicate within the 5G infrastructure. Besides a SIM, user equipment may be home appliances of any kind (e.g. computer, IoT devices, etc.).
- **Radio Unit (RU)** Is an element connecting user equipment with the operator network.
- **gNB** Next generation Node/Base Station is a node providing NR user plane and control plane protocol terminations towards the UE, and connected via the NG interface to the 5GC.
- **gNB Distributed Unit (gNB-DU)** gNB-DU a logical node hosting RLC, MAC and PHY layers of the gNB or en-gNB, and its partial operation. gNB-DU terminates the F1 interface connected with the gNB-CU.
- **gNB Central Unit (gNB-CU)** gNB-Central Unit (CU) is a logical node hosting RRC, SDAP and PDCP protocols of the gNB or RRC and PDCP protocols of the en-gNB that controls the operation of one or more gNB-DUs. The gNB-CU terminates the F1 interface connected with the gNB-DU.

GENERIC 5G ARCHITECTURE COMPONENTS

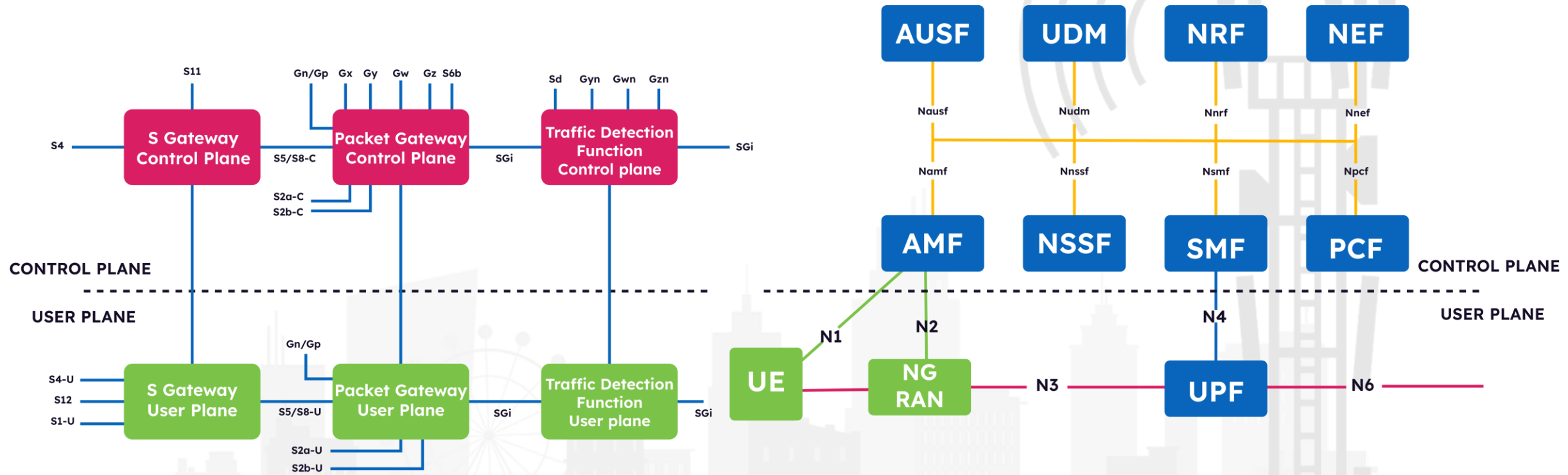
UE

5G RAN

5G CORE

- **F1** Logical interface with the F1 Application Protocol. (defined in ETSI TS 138 473)
- **Xn** is a network interface between NG-RAN nodes; 3GPP TS 38.420 specifies Xn interface general aspects and principle
- **NG interface** an element defined by ETSI 35 that has as purpose to logically separate signalling and data transport network.
- **Non Access Stratum (NAS)** NAS is a functional layer in the protocol stack between UE and Core Network. (NAS) protocol for 5G System. (defined in 3GPP TS 24.501).
- **Access Stratum (AS)** AS is a functional layer in the protocol stack between UE and RAN responsible for transporting data over the wireless connection and managing radio resources.

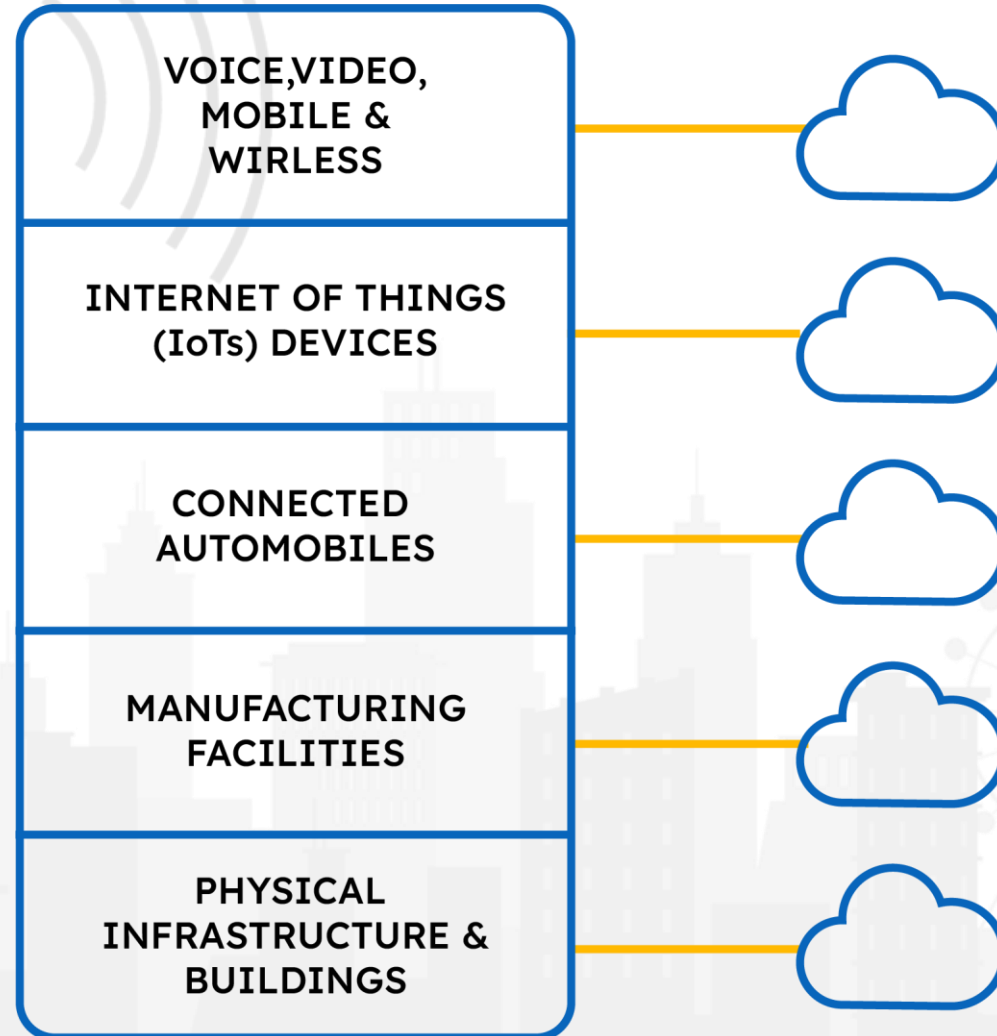
4G & 5G CORE



NETWORK SLICING SIMPLIFIED

- Network slicing in 5G allows you to create several virtual networks over a shared public network.
- It adds flexibility and efficiency to the utilization of the network resources.
- In network slicing, each slice can be configured for its own performance and throughput.
- The logical networks created on top of a single physical infrastructure give each slice its own characteristics.
- These slices help to meet the specific needs of application users.
- One network slice could cater to a virtual reality application with a need for high bandwidth and low latency. Another one can support a remote-control system that needs low bandwidth but high reliability.
- Overall, network slicing gives flexibility to service providers to enable a large variety of 5G applications and diversity of use cases, without the need to over-invest in a network infrastructure.

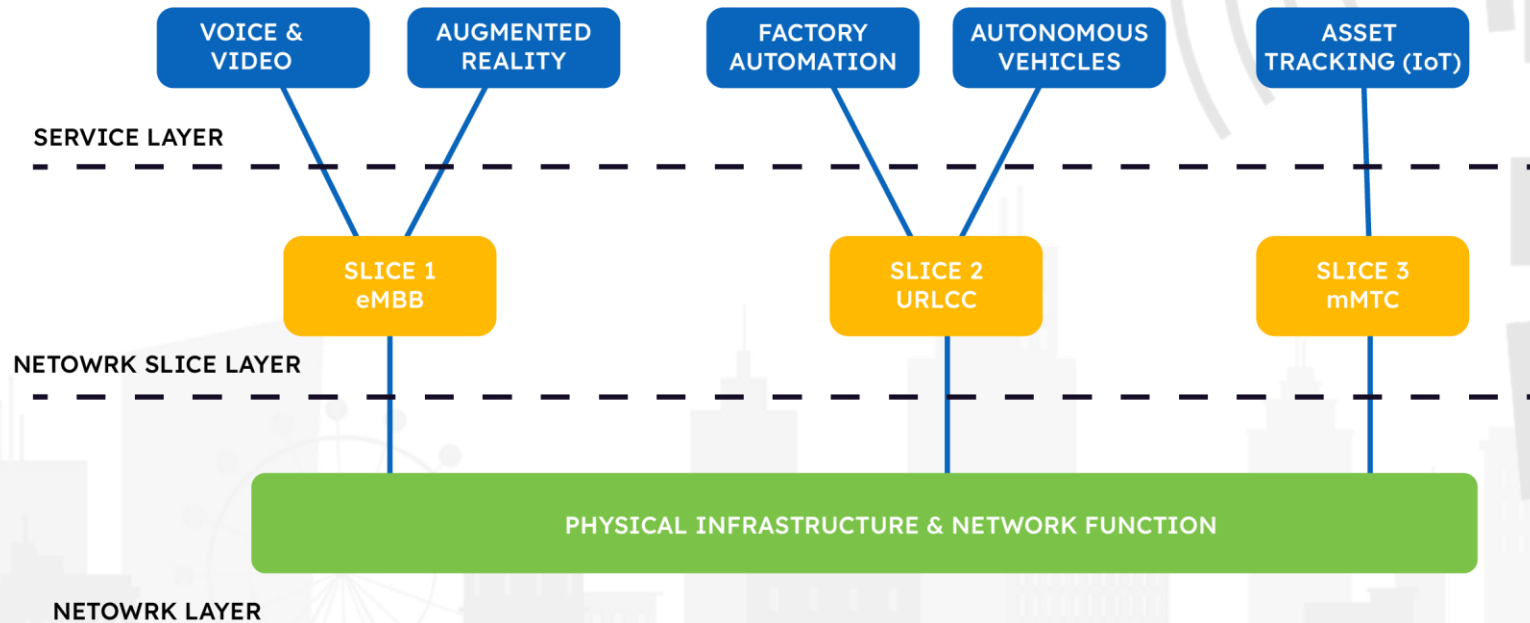
NETWORK SLICING



TYPICAL 5G NETWORK SLICING AT WORK

- Differential handling of traffic in network slicing.
 - Enhanced Mobile Broadband (eMBB): eMBB is a 5G service category that assures a minimum data transfer rate level. It is geared toward high data rates and high traffic volumes.
 - Ultra-Reliable and Low-Latency Communications (URLLC): URLLC caters to the need for ultra-low latency (such as below 1 MS each way) as well as very high reliability. It serves well in factory automation scenarios and the control of robots, remote surgery, and Vehicle to Everything (V2X) communication.
 - Massive Machine-Type Communication (mMTC): This is best suited for IoT devices and sensors that are often low-power but have a high density (defined by the number of devices per square area). These devices are often low-cost, transmit small packets infrequently, and are often delay-tolerant.

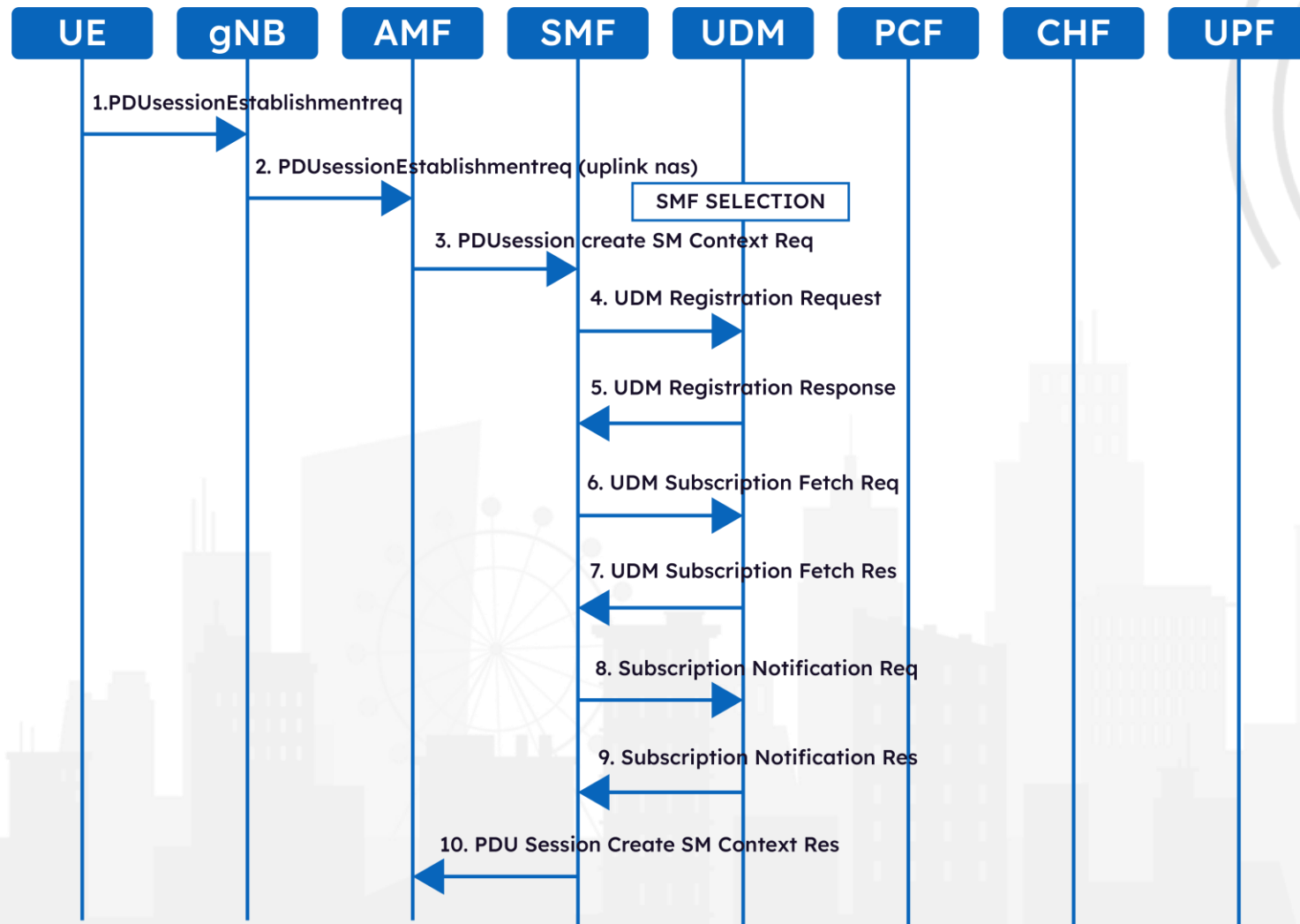
5G NETWORK SLICING AT WORK



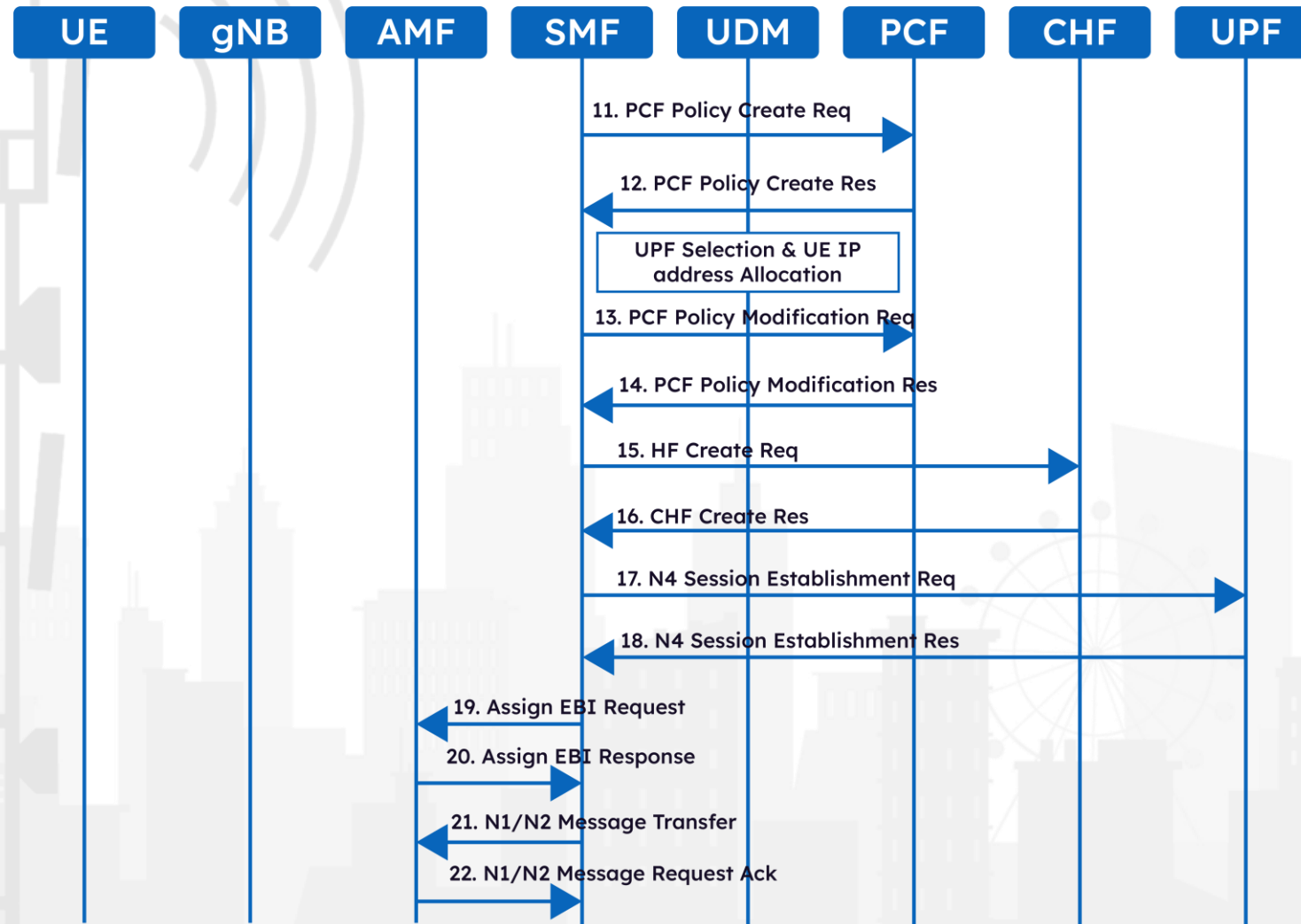
PACKET CORE PROCEDURE

- In previous slides we have seen **Protocol Data Unit (PDU)** session, wherein we learned that a PDU provides end-to-end connectivity to **user equipment (UE)** to avail of data services.
- A PDU session can be imagined to be a pipe that is associated with every UE and is identified by a PDU session ID this pipe is used for the user data to flow between the 5G packet core to the UE. The PDU session ID is generated by the UE.
- In next slide we will see how PDU session between UE and 5GS is established
- In this procedure following nodes are covered
 - **UE**
 - **gNB (gNodeB/RAN)**
 - **AMF (Access and Mobility Function)**
 - **SMF (Session Management Function)**
 - **SCP (Service Communications Proxy)**
 - **UDM (Unified Data Management)**
 - **PCF (Policy Control Function)**
 - **CHF (Charging Function)**
 - **UPF (User Plane Function)**
- Note that, optionally, a **Network Registration Function (NRF)** can also be used for service registration and discovery, but we have left it out of our example here for the sake of simplicity.

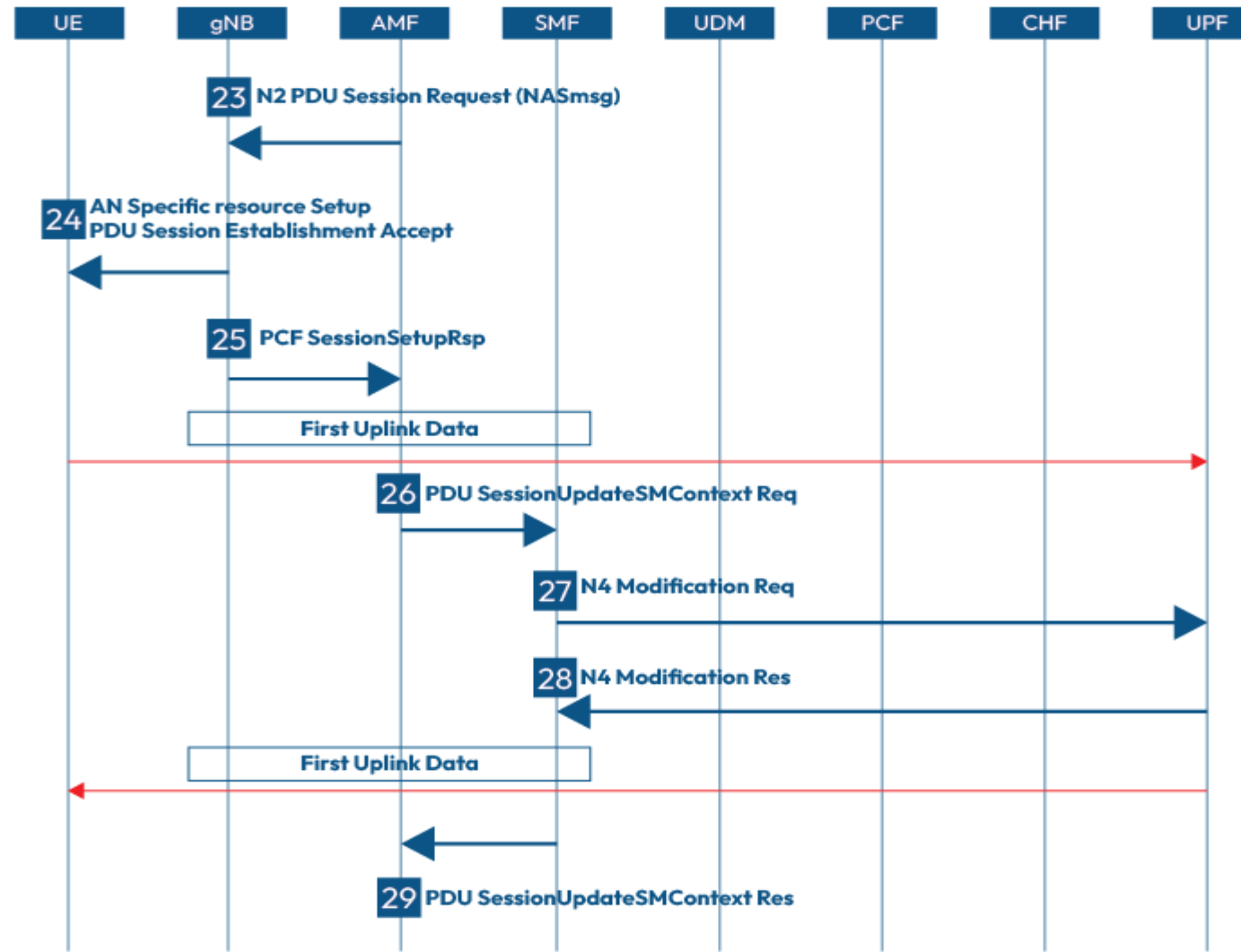
PDU SESSION ESTABLISHMENT IN 5G



PDU SESSION ESTABLISHMENT IN 5G

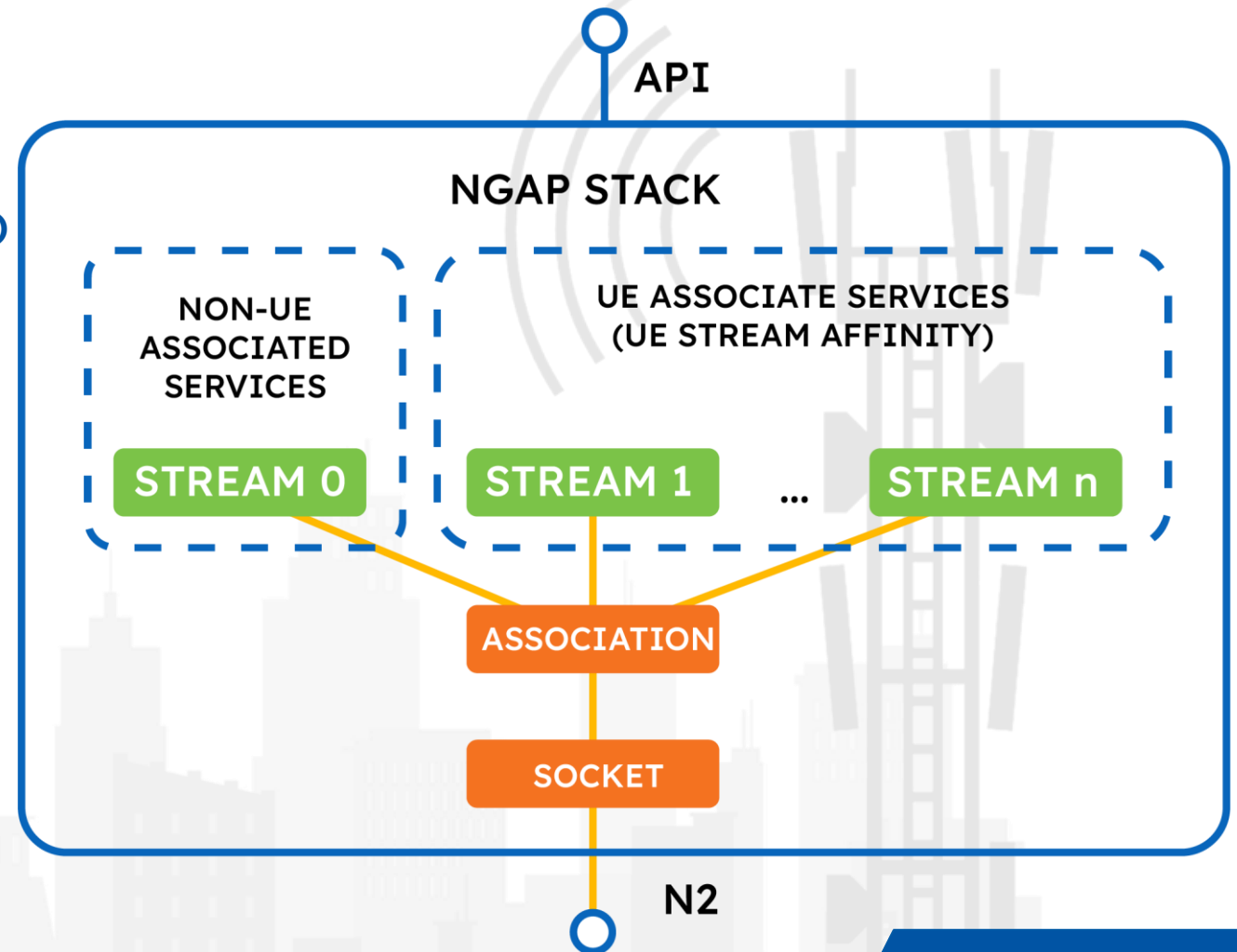


PDU SESSION ESTABLISHMENT IN 5G



NGAP INTERFACE

- **3GPP TS 38.413 NG Application Protocol (NGAP)**
- Sctp Based
- two groups
 - Non UE-associated services
 - UE-associated services

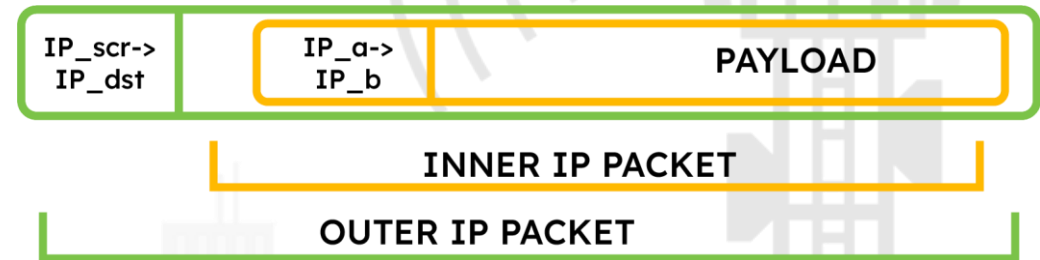




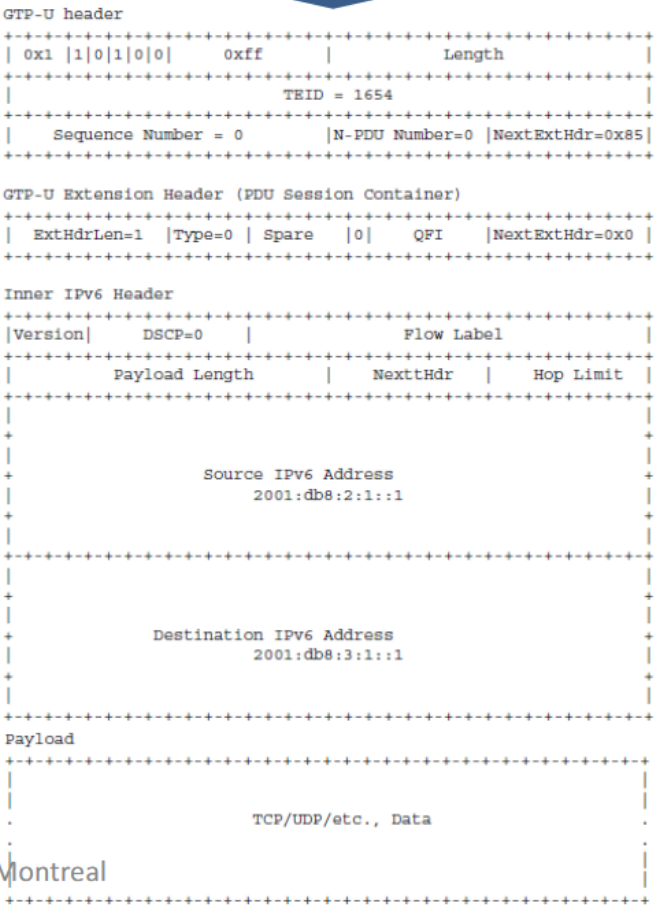
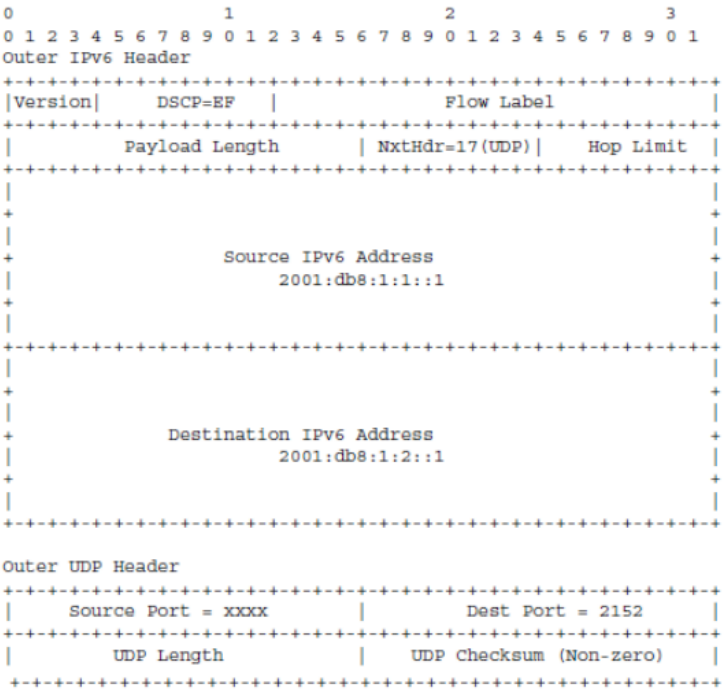
Sample NGAP Packet

GTP INTERFACE

- **It's a Tunnelling Protocol**
- **Use in N3 Interface in 5G**



GTP-U PACKET



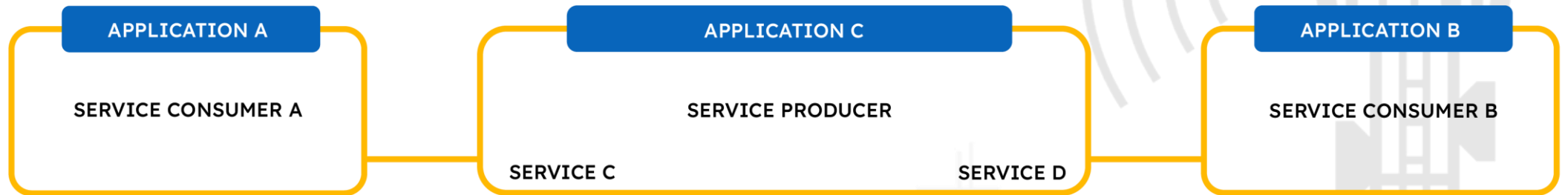


Sample GTP Packet

SBI INTERFACE: SERVICE BASED ARCHITECTURE

- As 5G has been developed on cloud principles, 5G NFs also follow web-scale application principles, so it is designed in a manner in which the NFs provide and consume services to and from each other.
- Hence, 5G is based on a producer-consumer model and 3rd Generation Partnership Project (3GPP) has chosen to use the widely adopted Representational State Transfer (REST) model to support communication between various NFs in 5G.
- A Service-Based Architecture (SBA) is a system architecture in which the functionality of the system is achieved by applications providing services and consuming services to and from each other.
- In the context of a 5G core, a service-based interface is between two NFs that provide or consume a service to or from each other.

BASIC IDEA OF REST API



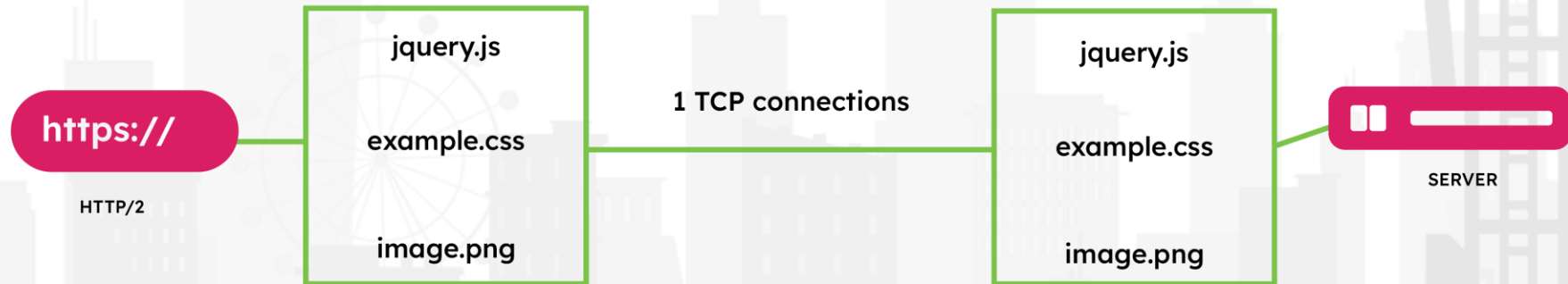
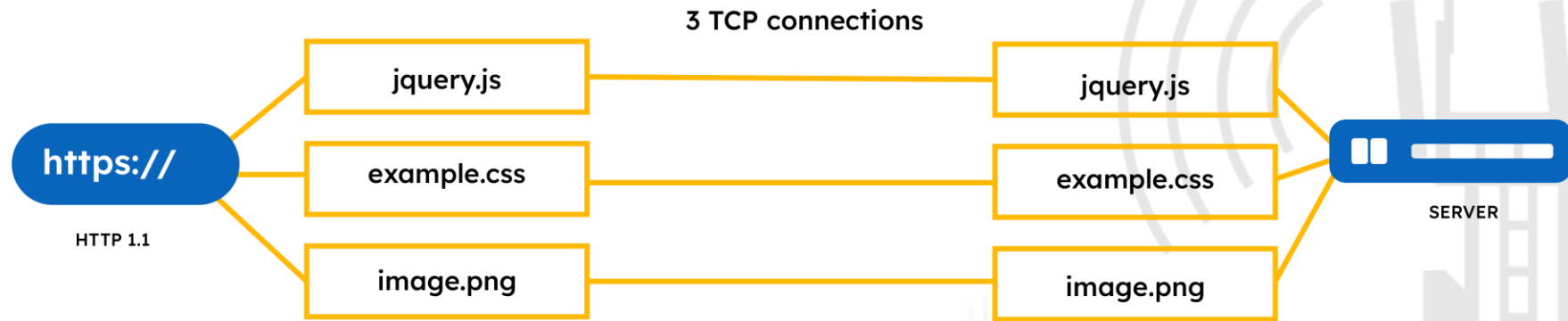
SERVICE CONSUMER A, HOSTED BY APPLICATION A,
CONSUMER THE SERVICE PROVIDED BY SERVICE
PRODUCER - SERVICE C, HOSTED BY APPLICATION C

SERVICE CONSUMER B, HOSTED BY APPLICATION B,
CONSUMER THE SERVICE PROVIDED BY SERVICE
PRODUCER - SERVICE D, HOSTED BY APPLICATION C

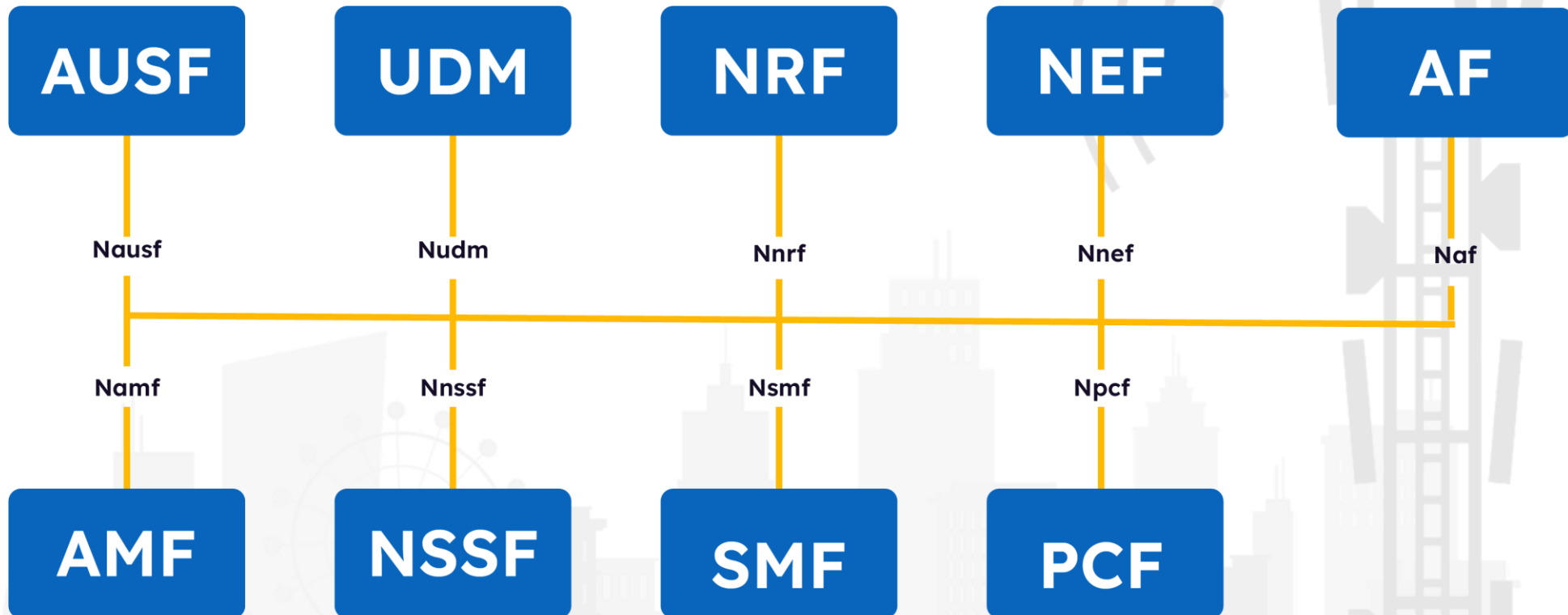
REST API

- REST is a style of software architecture and uses a subset of HTTP. REST is used to create web applications that provide and consume services from each other.
- It makes applications scalable and improves the modifiability of applications.
- It enhances the application performance and improves the simplicity of application communication.
- It ensures the portability of applications and ensures the reliability of applications.
- It is stateless and HTTP-based and has a standard set of operations (Create, Read, Update, and Delete (CRUD)).
- It is client/server-based and cacheable.
- It is a layered system and has a uniform interface.

Difference 1.1 vs 2.0



RESTFUL API IN 5G





Whats New

USER & CONTROL PLANE SEPERATION (CUPS)

- This helps to improve the efficiency and performance of the 5G network.
- As a result, the control plane and user plane serve as two different network components used to handle different kinds of network traffic.
- The control plane manages the network and maintains the communication between devices
- The control plane sets up and tears down connections, routes traffic, and manages resource allocation.
- The user plane carries the user data, including payloads such as voice and video.
- Independent scaling of the control plane and user plane can be done using CUPS.

Encrypted Identities

- 5G comes with identity concealment idea which encrypts the SUPI (aka IMSI in 2G/3G/4G) when registration is taking place
- This make it difficult for attacker to run IMSI catcher and collect identities in plain text
- It was possible to run IMSI catcher in earlier technologies to collect identities but with SUCI (encrypted SUPI) it becomes difficult for Attacker to identify SUPI

NEF (Exposure Function)

- NEF is used for allowing non 3gpp network or third party customer/businesses to access certain information about 5G users
- The information shared by NEF can be controlled and monitored
- Earlier technologies didn't have this features
- It uses REST API in both direction



Cloud Native Arch

- Most of the 5G network are deployed in form of Cloud Native Images
- This makes it easy to increase/decrease capacity and control as well



Slicing

- Network within Network
- Slicing allows prioritization of services allowing better QOS



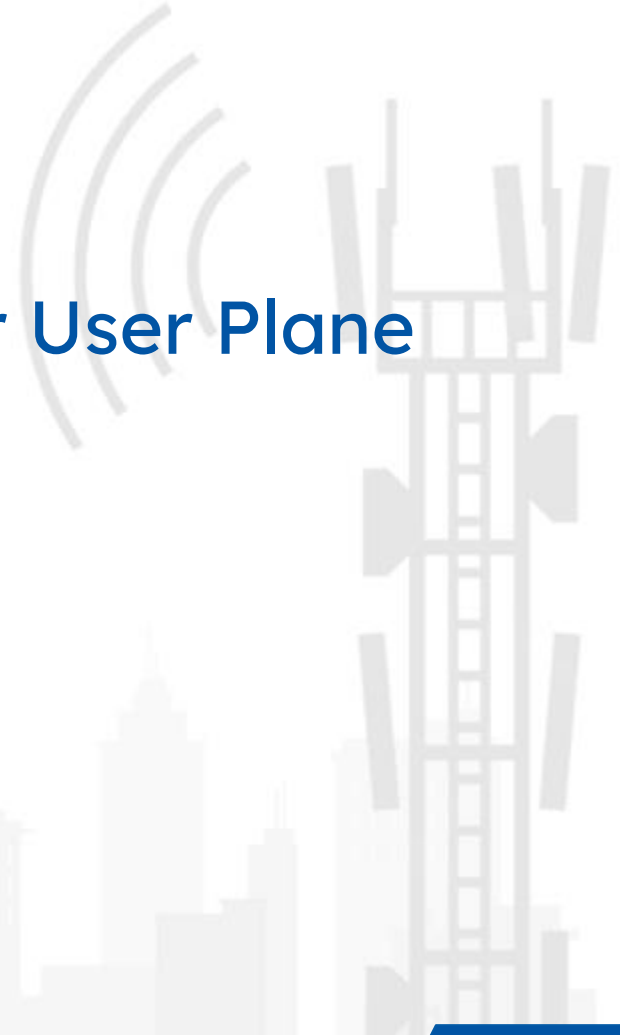
EDGE Computing

- Brings data Storage and computation closer thus reducing latency ,bandwidth usage, unnecessary transport



UP Security

- Integrity/Confidentiality Protection over User Plane



SBI and REST API

- Auth before Request (oAUTH)
- End to End Signalling Security
- ZERO TRUST



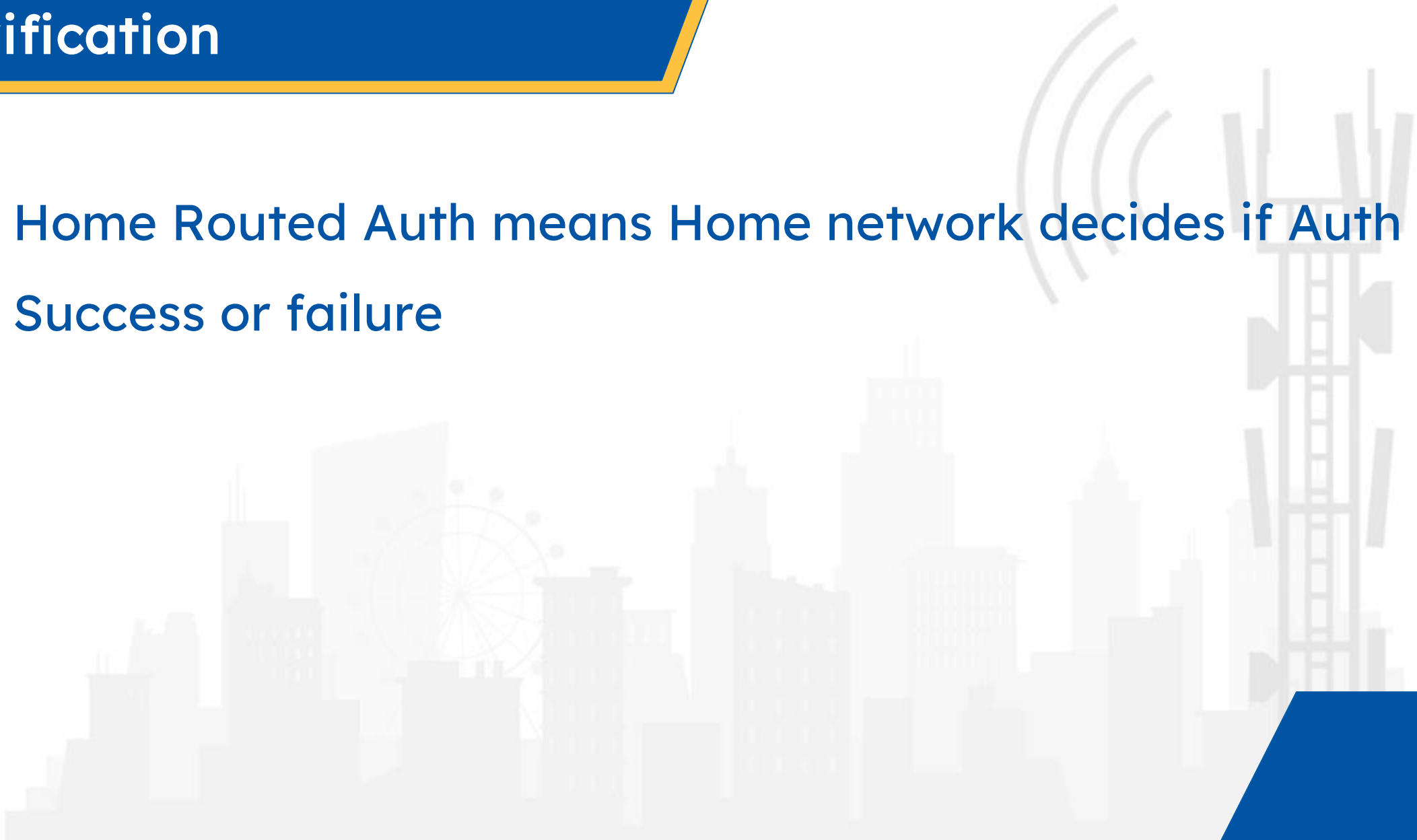
Roaming Firewall (SEPP)

- Secure Roaming
- End to End Security in Signalling



Home Routed Auth Verification

- Home Routed Auth means Home network decides if Auth is a Success or failure





5G SECURITY

CHALLENGES IN SECURING 5G

- Increased bandwidth increases protocol complexity
- Allow room for implementation vulnerabilities as well as config vulnerabilities

- Roaming interconnect mandates MNO to support legacy protocol for Roaming

- Container Security Threats Applies
- Traditional IT threats applies as well

Radio Access Network

01

Signaling Drag

02

Roaming Interconnect

03

Zombie UE

04

Edge Computing

05

V/C Based NFV Core

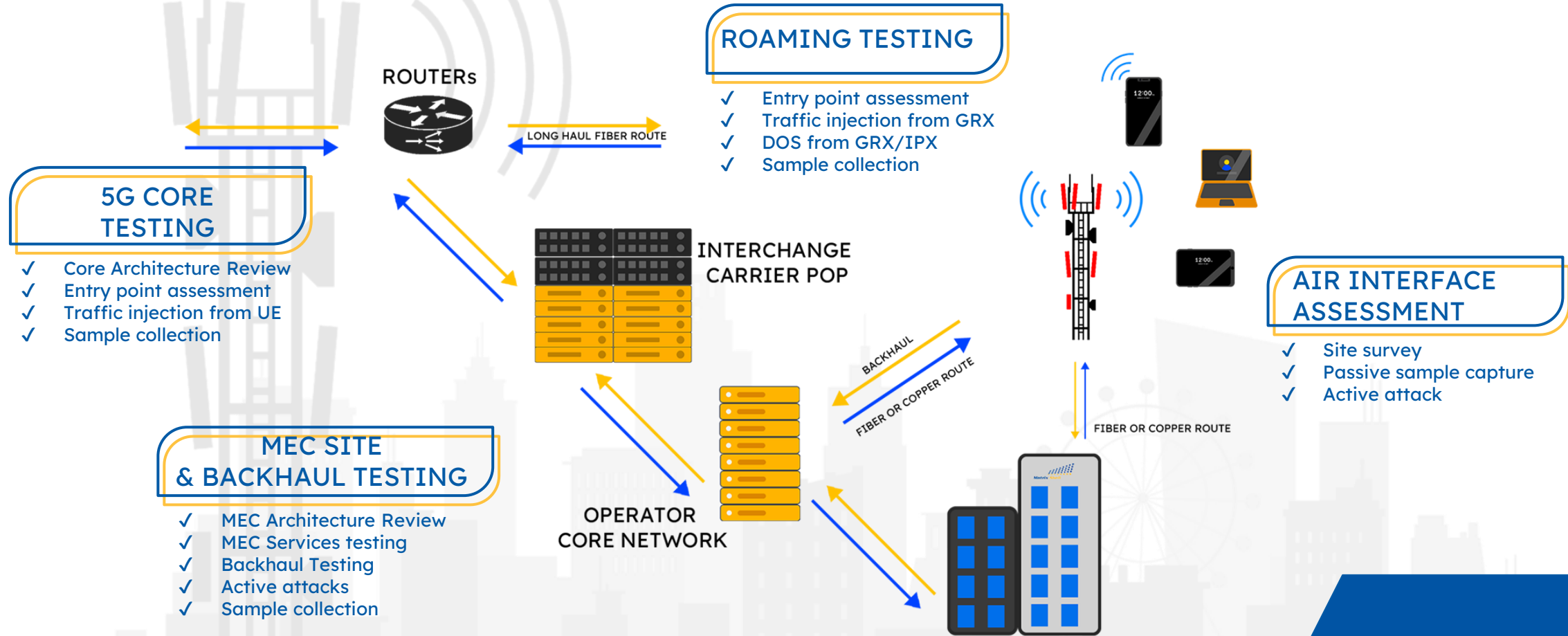
06

- Interoperable technologies (2G/3G/4G) create signalling drag
- This Allows older threats exist in network

- Threat of Zombie UE can generate DOS Attack towards other subscribers, Network.

- Configuration based issues
- API Security
- More Interfaces , more route leaks

5G SECURITY TESTING REQUIREMENTS

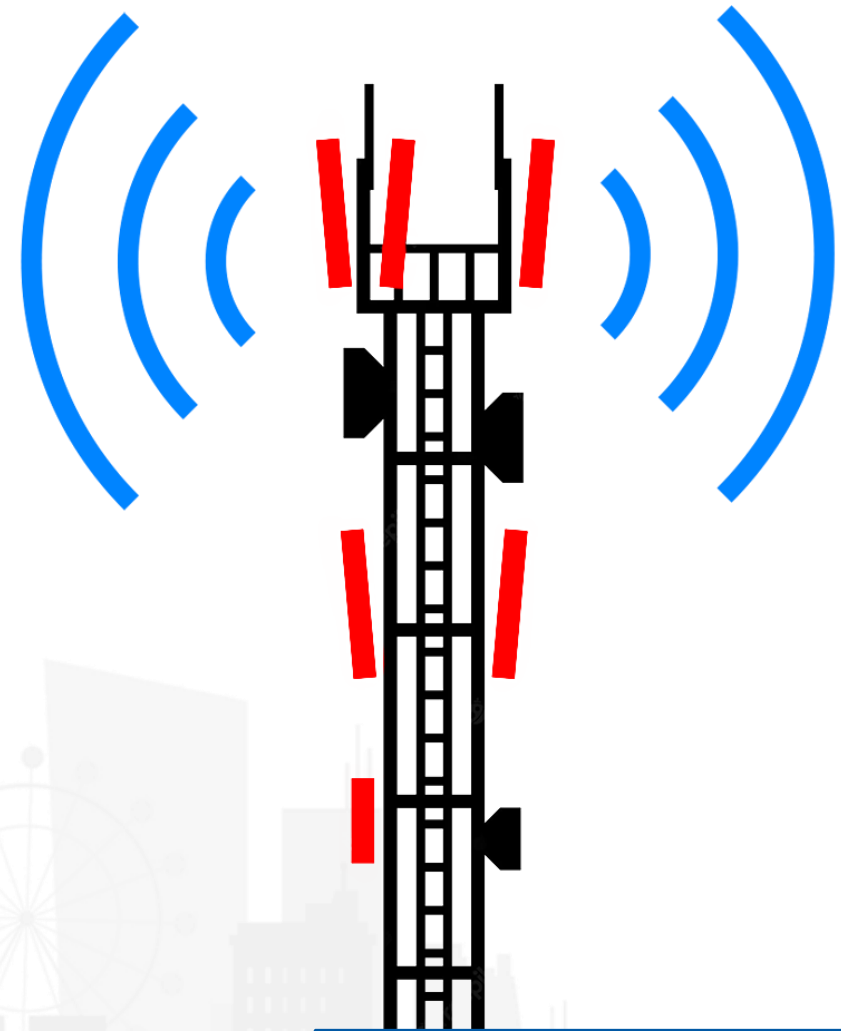


SECURITY TESTING REQUIREMENTS

Sr. No	Test Area	Test Case
Air Interface		
1	Radio Interface Assessment from UE	Air Interface Test Cases: • Configuration Vulnerabilities • NAS protocol vulnerabilities
2	Packet Capture & Architecture Analysis	• Analysis of Packet Traces from Different RAN related Nodes • Architecture Analysis of RAN network
MEC & Backhaul Threat		
1	MEC Platform Audit	Analysis of Different Models of MEC • PAAS or IAAS • Slicing Validation • Traffic Segregation
2	Fronthaul Mid-haul Backhaul Assessment	• Network Architecture Audit • Configuration Review • Traffic Analysis and Attack (O&M, User Data, Signalling)
3	MEC Web App Assessment	• Web App and Web API exposed

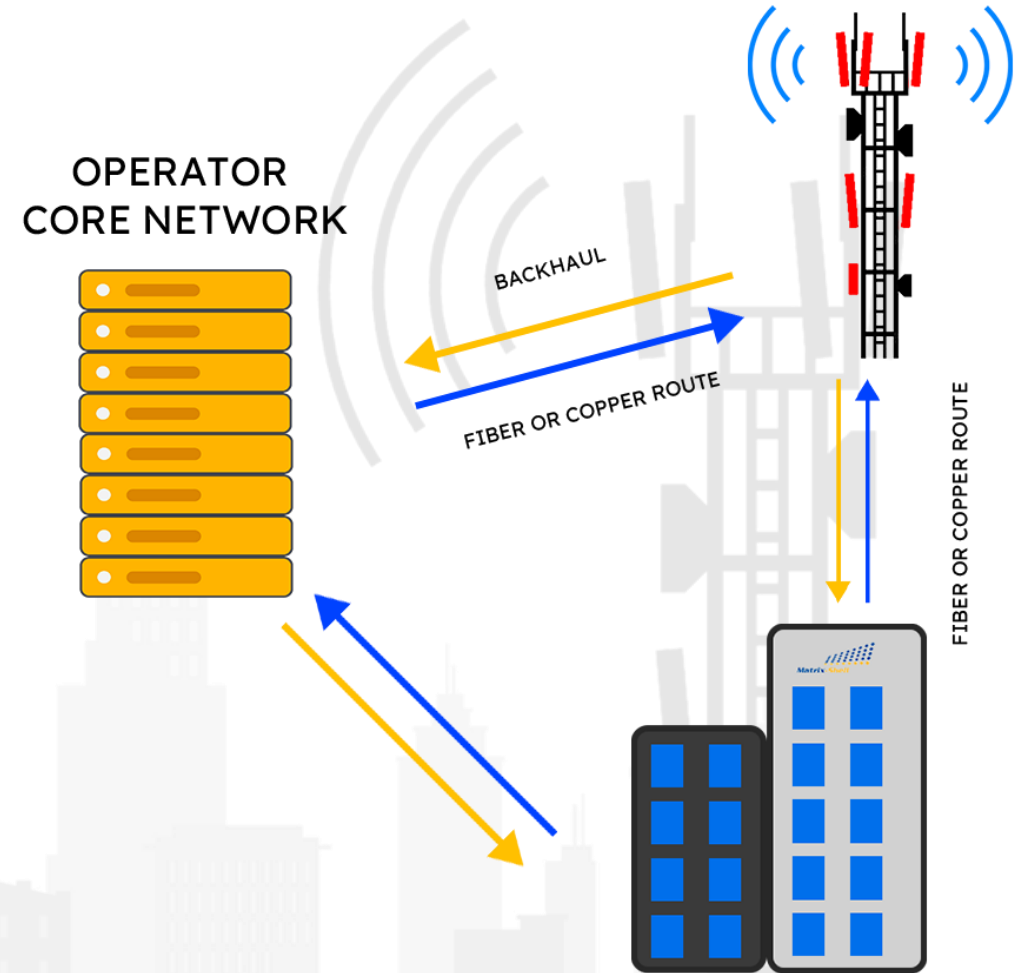
5G AIR INTERFACE THREAT TESTING

- **Physical Site Intrusion**
 - DOS
 - Traffic Interception
 - Core Network Intrusion from Physical Site
- **Configuration Vulnerabilities**
 - Encryption, Integrity Algorithm Config Abuse
- **NAS protocol vulnerabilities**
 - NAS Injection from Core
- **SCAS Validation on eNodeB and gNodeB**
- **Validation of encryption/integrity algorithm supported**
- **Priority of Encryption/integrity Algo**
- **Traffic generation to perform DOS**
- **Impersonate 5G NSA using diameter weakness**
- **Network sweep using from Radio Interface**
- **Tools in use**
 - UE Simulator (4G/5G NSA/5G SA)
 - Custom Tool, Scripts
 - 5G SA/NSA modem/smartphones



MEC & BACKHAUL TESTING

- Slicing Validation
 - Validating Different slices configuration
- Traffic Segregation
 - Traffic segregation validation & route leaking
- Network Architecture Audit (Backhaul)
- Configuration Review (Backhaul)
- Traffic Analysis and Attack (O&M, User Data, Signalling) (Backhaul)
- Web App and Web API exposed
- Tools in use
 - UE Simulator
 - Traffic Analysis Tools – Wireshark
 - OWASP Security Testing Tools :- Iron WASP/Burp Suite



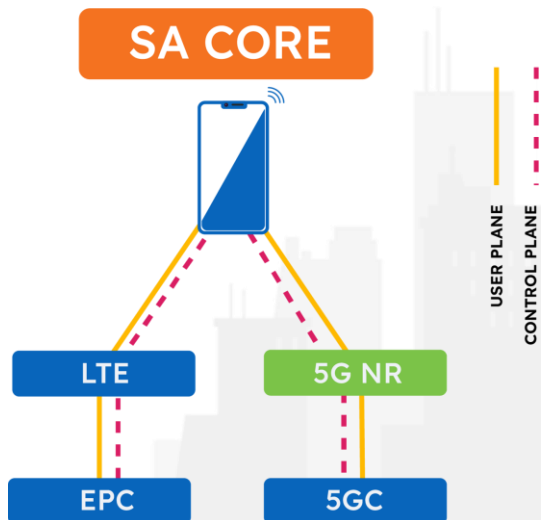
5G SECURITY & TEST CASES

Sr. No	Test Area	Test Case
5G Core Testing		
1	5G Slicing Validations	• Different Slicing Validation
2	Signalling Protocol Assessment for 5G Core SA	• Testing HTTP2/JSON Based Attacks on Core Network • PFCP Protocol Testing • DOS Attacks
3	Simulating Internal Attacker	• Privilege escalation • Unauthorized Hypervisor/VM/NFV Access • Distro Specific vulnerabilities
Roaming Testing		
1	Diameter Security Testing	Complete Diameter Roaming Interconnect Security Assessment
2	GTP Security Testing	Complete GTP Roaming Interconnect Security Assessment

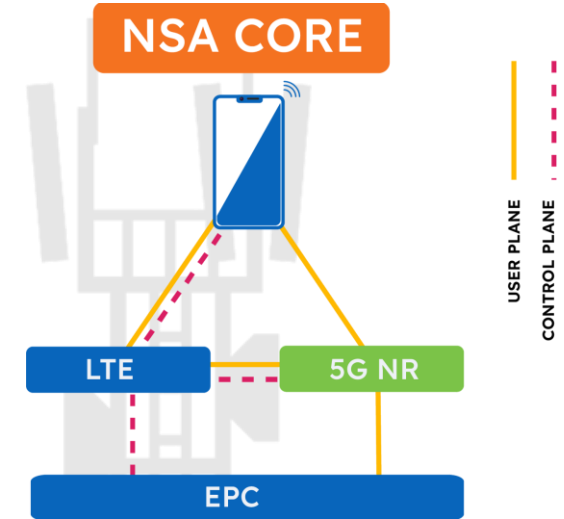
SA & NSA CORE TESTING

- Drags threats of 4G signalling such as
 - Network Impersonation for Data/Call/SMS Interception
 - Fallback attack towards legacy(2G/3G) Technologies
- Identify different path
 - Route Leaking
 - Core exposure in user plane
 - Lack of Slicing segregation
- Configuration review

- Tools/Standards in use
 - UE Simulator (5G NSA/SA)
 - Traffic Analysis Tools – Wireshark
 - Scripting
 - Custom HTTP2 Client
 - 3GPP SCAS Documentation



- 5G service in a Standalone Mode
- 5G RAN and its 5G Core
- No impact of legacy tech but New threat vectors
 - NFV/SDN threats
 - Lack of Integrity check in User Plane
 - Risk of Open Source
 - Lack of Code Signing
- 5G Core HTTP2/JSON API Threats
 - Malformed Traffic generation
- PFCP Protocol Testing
- SCAS validation for 5G Core





SETTING UP LAB

SETTING UP INFRASTRUCTURE

- Setting UP VM
- Setting UP docker based 5G Core
- Setting UP IMS
- Installing UERANSIM
- Setting UP local Infra



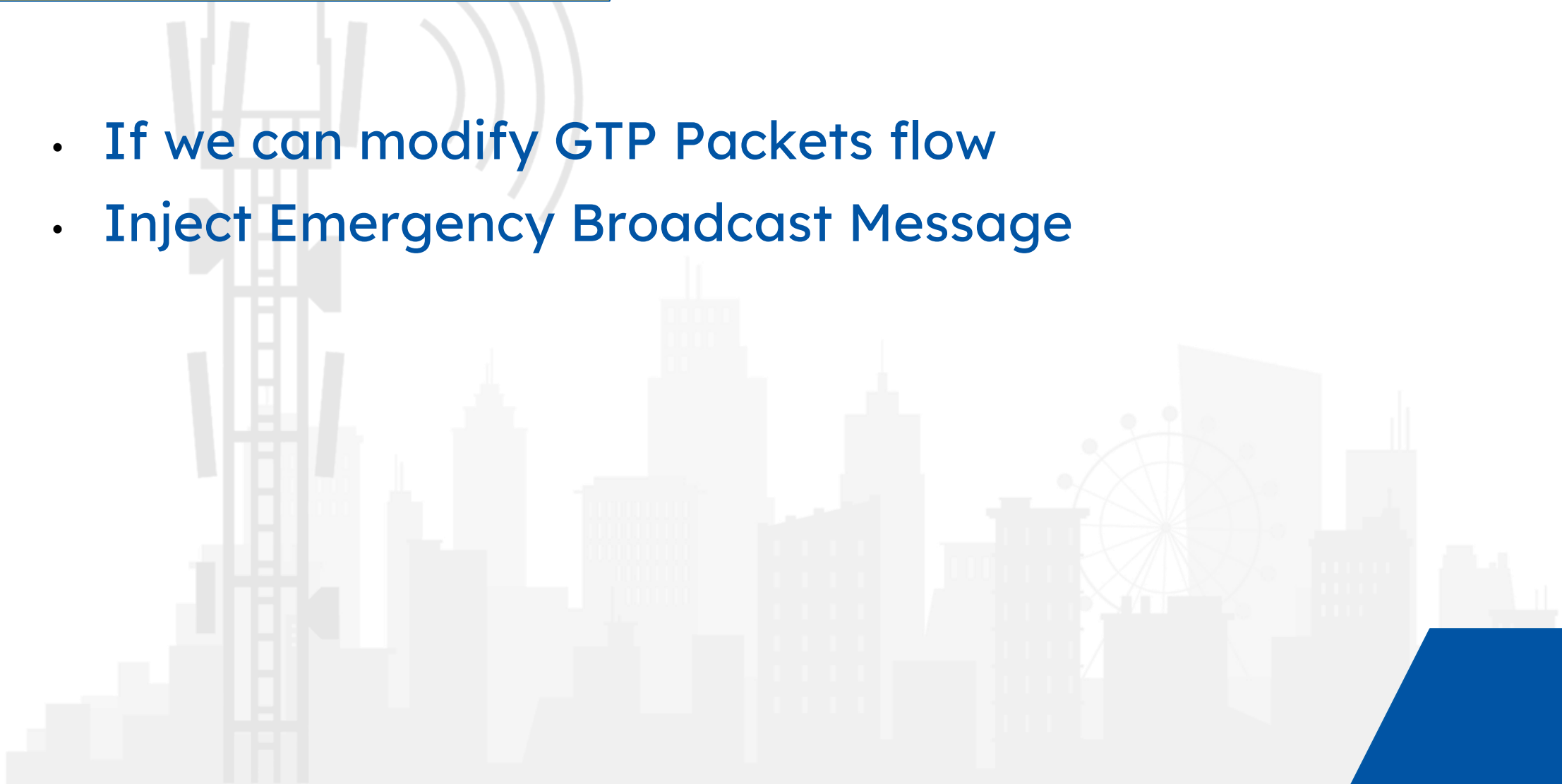
COMMUNICATION ANALYSIS PRACTICE

- NGAP
- GTP
- SBI Interface



NGAP- WHAT TO LOOK FOR

- If we can modify GTP Packets flow
- Inject Emergency Broadcast Message



GTP- WHAT TO LOOK FOR

- Tunnel ID randomization



SBI- WHAT TO LOOK FOR

- API/ oAUTH Weakness
- Direct communication by bypassing SCP

DATA PLANE

- Route Leaks
- Crossover on Slices
- Data DNN to Other DNN

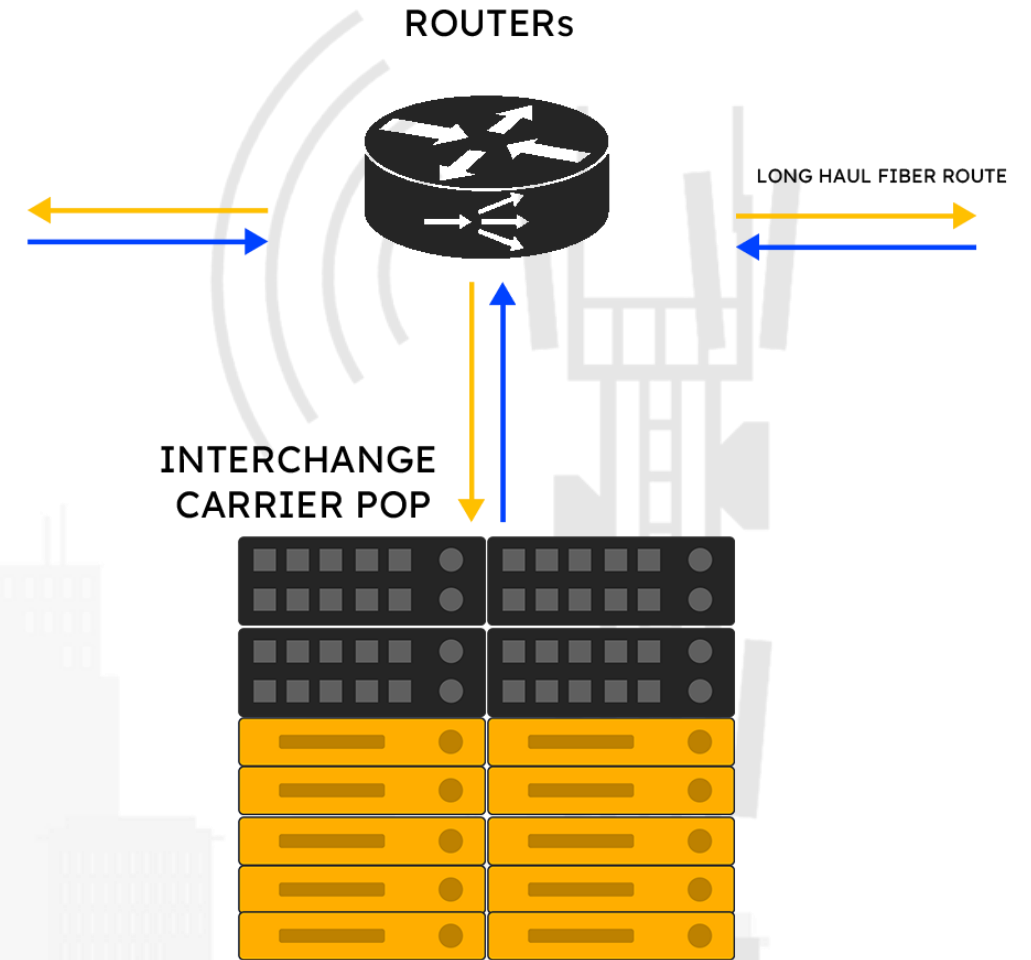


SOFTWARE IMPLEMENTATION VULNERABILITIES

- Fuzzing
- Web Portal (OWASP TOP 10) of NF
- CWE for NF

ROAMING & INTERNET TESTING

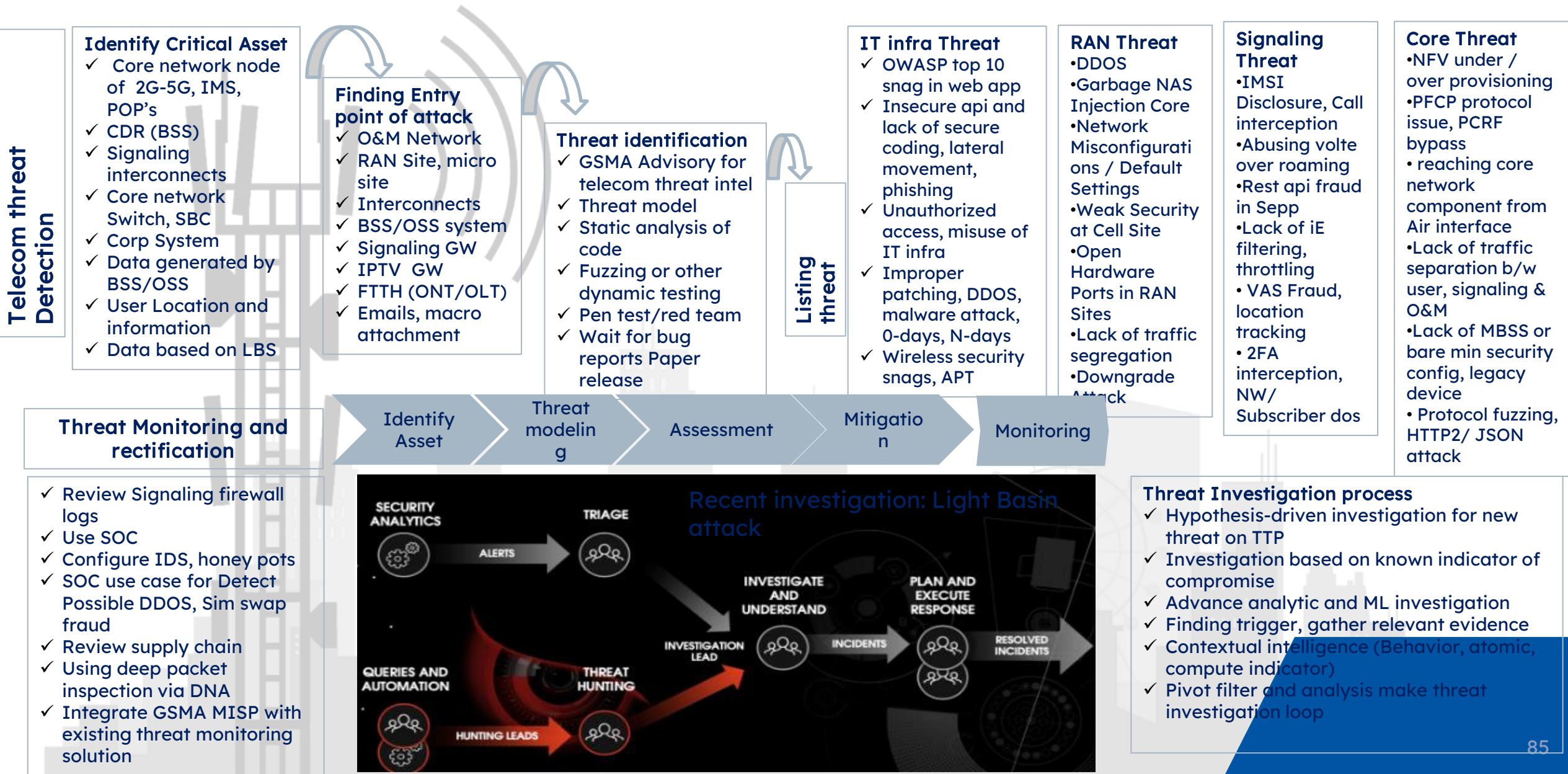
- Diameter Security Testing
- GTP Security Testing
- Internet Security Testing (5G)
- PFCP exploitation
- Attacking neighbour
- Using http/2 to exploit 5G Core signalling
- Analyse VM configuration





5G Threat Model

What processes/steps should be followed to monitor, detect and investigate threats specifically for telecom products and IT infrastructure. Please also elaborate on rectification procedures according to your best knowledge.



enumeration towards Core {Attack surface}

- Access Side (MS, RAN, microsite)
 - UE rotted device, srsue,
 - Unprotected RAN, unauthorized access to remote ran site
 - Femto Cell , finding IPsec key,
 - APN Fuzzing
 - OSS/BSS application exposure towards internet
 - MEC expose api
 - Nbiot end points
 - Public exposure of O&M interface
 - Supply chain vendor
 - Social engineering
 - NAS Device, CPE, internet gateway
 - Bitstream lack of segregation towards PPOI routers

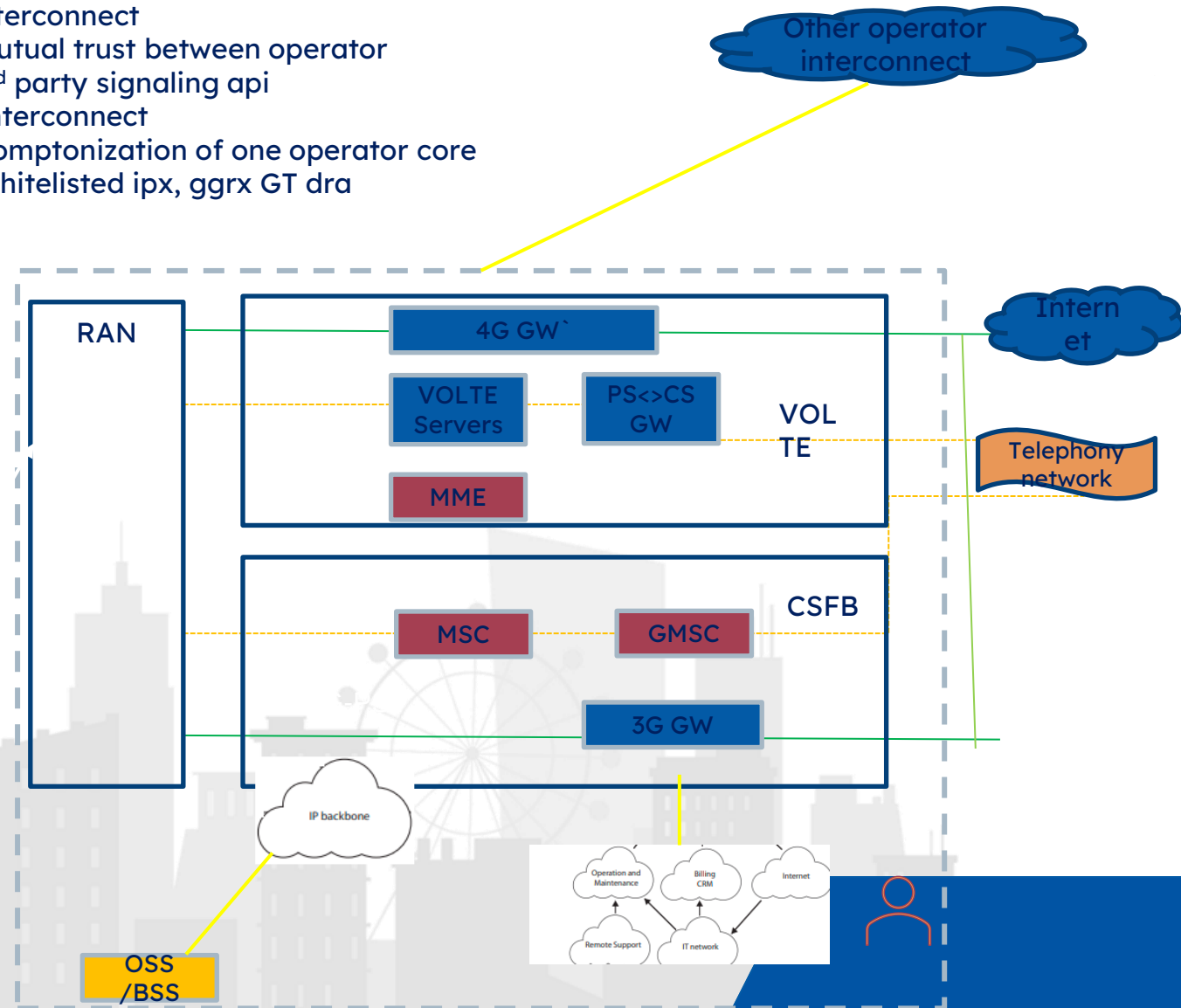
Case Study

- Scanning internal node from UE, modem, CPE
- Fuzzing different -2 Aprn ,
- Location change, connect to different radio provide {nokia, Ericsson, Huawei}
- Using voice interface to scan send traffic towards internal node

Prevention

- Scanning internal node from UE, modem, CPE

- Signaling interconnect
 - Mutual trust between operator
 - 3rd party signaling api
 - Interconnect
 - Comptonization of one operator core
 - Whitelisted ipx, ggrx GT dra



Objective: Please elaborate on the STRIDE threat modelling and steps to implement and use this in any organization

Ways to Find Security Issues

- **Threat model**
- Static analysis of code
- Fuzzing or other dynamic testing
- Pen test/red team
- Wait for bug reports Paper release

- What are your most valuable assets?
- What are the potential threats to your device?
- What type of attack do you need to protect against?
- How severe are the threats?
- What counter-measures could you implement?
- What are your security requirements?
- How does your device meet your security requirement

Asset identification

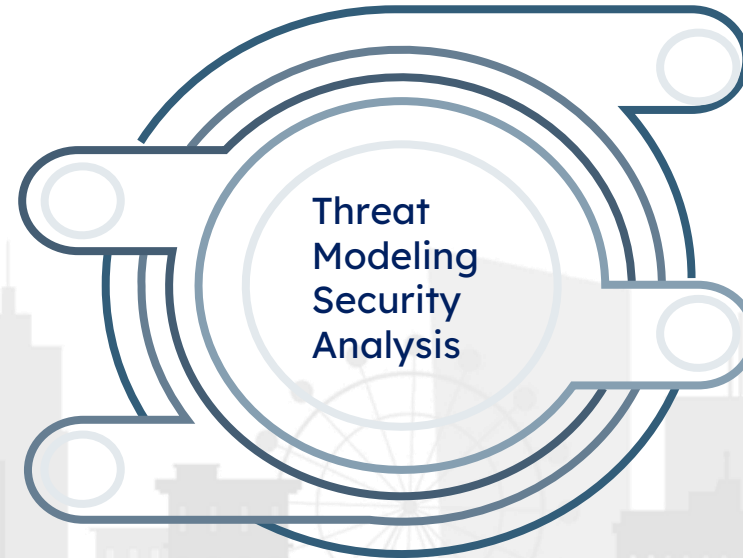
- Radio access network
- Core network
- Multi-access Edge Computing
- Physical infrastructure
- Virtualization
- UE, session, Api's, Application data

Identify Threat/ vuln & analysis

- Fake access node / abuse by rouge cloud service provide
- IMSI Cather, rouge MEC gateway
- Memory scraping in SDN, session hijacking
- Edge api exploitation or lateral movement in core NF
- Signaling fraud

Mitigation

- Zero-trust architecture approach
- Segmentation and isolation at network and application layers
- Policy-based security management
- Security controls automation Granular user access control
- Strong authentication and end point protection
- Certification and compliance of equipment and (virtual) network



Actor Definition

- Internal Actor: Rouge Admin, privileged insider, user(intentional/accidental)
- External operator: End user, external trusted operator, vendor, former authorized user, attacker, competitor,



STRIDE -5G Slicing

Tampering	Integrity	Modifying data on disk, memory, network, etc.,
-----------	-----------	--

- NFVO/ Hyper -V message tampering
- Rogue node between the Orchestrator and Host
- VNF image integrity
- Registration of malicious network function

Information Disclosure	Confidentiality	Providing information to someone who is not authorized
------------------------	-----------------	--

- Cross Slice secrete extraction
- Side Channel attack
- Lack of signaling & O&M traffic
- JSON based attack

Elevation of Privilege	Authorization	Allowing access to someone without proper authorization
------------------------	---------------	---

- UE Access to multiple slices with same auth
- Lack of authorization in slicing components
- Authentication relaxation for service/ latency

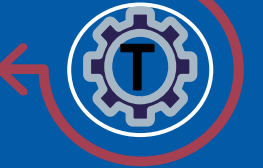


Spoofing

Authentication

Impersonating something or someone known and trusted.

- MITM (man in middle)
- Impersonation of NSMF or host
- NSSAI Spoofing
- Impersonation of SMF
- Hyper-V compromised via api

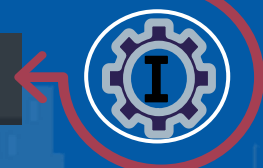


Repudiation

Non-repudiation

Claim to not be responsible for an action

- Malicious activates from temp/unused vendor acc
- Spike in authentication traffic
- Slicing ID tampering
- Under/Over provisioning



D

Denial of Service (DoS)

Availability

Denying or obstructing access to resources required to provide service

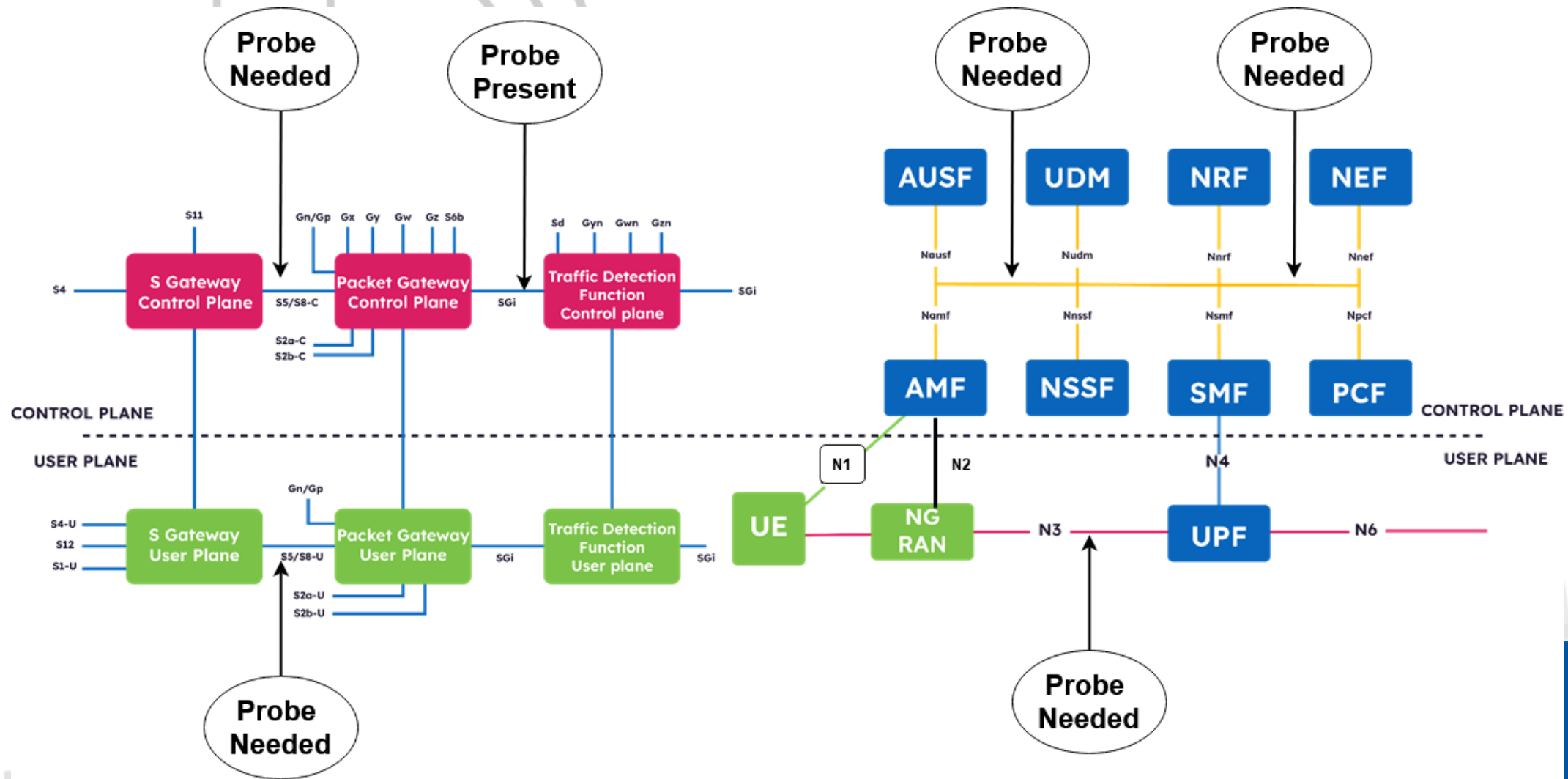
- Exhaustion shared sec service
- DOS/DDOS
- Amplification
- Direct attack on NFV/ MANO





Monitoring 4G/5G

4G/5G Monitoring Requirement



Run Core and RAN

- OS requirement Ubuntu 22.04 and Above
- SCTP support
- Docker support
- Download docker files from here
- https://drive.google.com/file/d/1UxkWs2fijlq8_xirGL8P3vWGV12tCzq/view?usp=sharing

The background is a solid blue color. On the left side, there is a stylized illustration of a communication tower with several antennas and signal waves emanating from it. Below the tower and across the bottom of the image is a silhouette of a city skyline with various buildings and a Ferris wheel. The text "THANK YOU!" is centered in the middle of the image in a white, bold, sans-serif font.

THANK YOU!